

BUNDESGESETZBLATT

FÜR DIE REPUBLIK ÖSTERREICH

Jahrgang 2025	Ausgegeben am 23. Dezember 2025	Teil I
94. Bundesgesetz:	Netz- und Informationssystemsicherheitsgesetz 2026 sowie Änderung des Telekommunikationsgesetzes 2021 und des Gesundheitstelematikgesetzes 2012 (NR: GP XXVIII RV 308 AB 354 S. 59. BR: 11725 AB 11726 S. 985.) [CELEX-Nr.: 32022L2555]	

94. Bundesgesetz, mit dem das Bundesgesetz zur Gewährleistung eines hohen Cybersicherheitsniveaus von Netz- und Informationssystemen (Netz- und Informationssystemsicherheitsgesetz 2026 – NISG 2026) erlassen wird und das Telekommunikationsgesetz 2021 und das Gesundheitstelematikgesetz 2012 geändert werden

Der Nationalrat hat beschlossen:

Inhaltsverzeichnis

Art.	Gegenstand / Bezeichnung
1	Netz- und Informationssystemsicherheitsgesetz 2026
2	Änderung des Telekommunikationsgesetzes 2021
3	Änderung des Gesundheitstelematikgesetzes 2012

Artikel 1

Bundesgesetz zur Gewährleistung eines hohen Cybersicherheitsniveaus von Netz- und Informationssystemen (Netz- und Informationssystemsicherheitsgesetz 2026 – NISG 2026)

Inhaltsverzeichnis

1. Hauptstück

Allgemeine Bestimmungen

- § 1. Verfassungsbestimmung
- § 2. Gegenstand und Ziel des Gesetzes
- § 3. Begriffsbestimmungen

2. Hauptstück

Strukturen und Aufgaben

1. Abschnitt

Zuständige Behörde

- § 3a. Bundesamt für Cybersicherheit
- § 3b. Organisation
- § 4. Aufgaben der Cybersicherheitsbehörde
- § 5. Zentrale Anlaufstelle der Cybersicherheitsbehörde
- § 6. Nationales Koordinierungszentrum für Cybersicherheit

2. Abschnitt**Unabhängige Stellen und unabhängige Prüfer**

- § 7. Unabhängige Stellen und unabhängige Prüfer

3. Abschnitt**Computer-Notfallteams**

- § 8. Zweck und Aufgaben der Computer-Notfallteams
§ 9. Anforderungen und Eignung von CSIRTs
§ 10. Aufsicht
§ 11. Koordinierte Offenlegung von Schwachstellen

4. Abschnitt**Nationale Koordinierung**

- § 12. Cyber Sicherheit Steuerungsgruppe (CSS)
§ 13. Innerer Kreis der Operativen Koordinierungsstruktur (IKDOK)
§ 14. Operative Koordinierungsstruktur (OpKoord)
§ 15. Nationale Cybersicherheitsstrategie
§ 16. Management von Cybersicherheitsvorfällen großen Ausmaßes

5. Abschnitt**IKT-Lösungen**

- § 17. Betrieb von IKT-Lösungen
§ 18. Meldeanalysesystem
§ 19. IKDOK-Plattform

6. Abschnitt**Zusammenarbeit auf nationaler, Unions- und internationaler Ebene**

- § 20. Zusammenarbeit auf nationaler Ebene
§ 21. Zusammenarbeit mit der Datenschutzbehörde
§ 22. Internationale Zusammenarbeit
§ 23. Peer Reviews

3. Hauptstück**Wesentliche und wichtige Einrichtungen und Einrichtungen, die Domänennamen-Registrierungsdienste erbringen****1. Abschnitt****Wesentliche und wichtige Einrichtungen**

- § 24. Wesentliche und wichtige Einrichtungen
§ 25. Ermittlung der Unternehmensgröße
§ 26. Größenunabhängige Einstufung als wesentliche oder wichtige Einrichtung
§ 27. Ausnahmen von Verpflichtungen für wesentliche oder wichtige Einrichtungen aufgrund sektorspezifischer Rechtsakte der Europäischen Union
§ 28. Territorialität

2. Abschnitt**Pflichten**

- § 29. Register der Einrichtungen
§ 30. Datenbank der Domänennamen-Registrierungsdaten
§ 31. Governance
§ 32. Risikomanagementmaßnahmen im Bereich der Cybersicherheit
§ 33. Nachweis der Wirksamkeit von Risikomanagementmaßnahmen
§ 34. Berichtspflichten
§ 35. Erheblicher Cybersicherheitsvorfall

3. Abschnitt**Informationsaustausch**

- § 36. Vereinbarungen über den Austausch von Informationen zur Cybersicherheit
§ 37. Freiwillige Meldung relevanter Informationen

4. Abschnitt **Aufsicht und Durchsetzung**

- § 38. Aufsichtsmaßnahmen in Bezug auf wesentliche und wichtige Einrichtungen
- § 39. Durchsetzungsmaßnahmen in Bezug auf wesentliche und wichtige Einrichtungen
- § 40. Nutzung der europäischen Schemata für die Cybersicherheitszertifizierung
- § 41. Beschwerdeverfahren

4. Hauptstück **Datenschutz**

- § 42. Datenverarbeitung
- § 43. Datenübermittlung

5. Hauptstück **Strafbestimmungen**

- § 44. Allgemeine Bedingungen für die Verhängung von Geldstrafen
- § 45. Verwaltungsstrafbestimmungen
- § 46. Nichteinhaltung von Verpflichtungen durch Stellen der öffentlichen Verwaltung

6. Hauptstück **Schlussbestimmungen**

- § 47. Personenbezogene Bezeichnungen
- § 48. Durchführung und Umsetzung von Rechtsakten der Europäischen Union
- § 49. Verweisungen
- § 50. Vollziehung
- § 51. Inkrafttretens-, Außerkrafttretens- und Übergangsbestimmungen

1. Hauptstück **Allgemeine Bestimmungen**

Verfassungsbestimmung

§ 1. (Verfassungsbestimmung) (1) Die Erlassung, Aufhebung sowie Vollziehung von Vorschriften, wie sie in diesem Bundesgesetz enthalten sind, sind auch in den Belangen Bundessache, hinsichtlich deren das Bundes-Verfassungsgesetz (B-VG), BGBl. Nr. 1/1930, etwas anderes bestimmt. Die in diesem Bundesgesetz geregelten Angelegenheiten können unmittelbar von Bundesbehörden besorgt werden.

(2) Soweit in diesem Bundesgesetz nicht anders bestimmt ist, übt die Cybersicherheitsbehörde ihre Befugnisse nach diesem Bundesgesetz auch gegenüber den in Art. 19 B-VG bezeichneten obersten Organen der Vollziehung aus.

Gegenstand und Ziel des Gesetzes

§ 2. Mit diesem Bundesgesetz werden Maßnahmen festgelegt, mit denen ein hohes Cybersicherheitsniveau, insbesondere von wesentlichen und wichtigen Einrichtungen in den Sektoren

1. Energie,
2. Verkehr,
3. Bankwesen,
4. Finanzmarktinfrastrukturen,
5. Gesundheitswesen,
6. Trinkwasser,
7. Abwasser,
8. Digitale Infrastruktur,
9. Verwaltung von IKT-Diensten (Business-to-Business),
10. Öffentliche Verwaltung,
11. Weltraum,
12. Post- und Kurierdienste,
13. Abfallbewirtschaftung,
14. Produktion, Herstellung und Handel mit chemischen Stoffen,
15. Produktion, Verarbeitung und Vertrieb von Lebensmitteln,
16. Verarbeitendes Gewerbe und Herstellung von Waren,

17. Anbieter digitaler Dienste sowie
18. Forschung,
und den zugehörigen Teilsektoren nach den **Anlagen 1 und 2** erreicht werden soll.

Begriffsbestimmungen

§ 3. Im Sinne dieses Bundesgesetzes bedeutet

1. „Netz- und Informationssystem“
 - a) ein Kommunikationsnetz gemäß § 4 Z 1 des Telekommunikationsgesetzes 2021 (TKG 2021), BGBl. I Nr. 190/2021,
 - b) ein Gerät oder eine Gruppe miteinander verbundener oder zusammenhängender Geräte, die einzeln oder zu mehreren auf der Grundlage eines Programms die automatische Verarbeitung digitaler Daten durchführen, oder
 - c) digitale Daten, die von den in lit. a und b genannten Elementen zum Zwecke ihres Betriebs, ihrer Nutzung, ihres Schutzes und ihrer Pflege gespeichert, verarbeitet, abgerufen oder übertragen werden;
2. „Sicherheit von Netz- und Informationssystemen“ die Fähigkeit von Netz- und Informationssystemen, auf einem bestimmten Vertrauensniveau alle Ereignisse abzuwehren, die die Verfügbarkeit, Authentizität, Integrität oder Vertraulichkeit gespeicherter, übermittelter oder verarbeiteter Daten oder der Dienste, die über diese Netz- und Informationssysteme angeboten werden oder zugänglich sind, beeinträchtigen können;
3. „Cybersicherheit“ alle Tätigkeiten, die notwendig sind, um Netz- und Informationssysteme, die Nutzer solcher Systeme und andere von Cyberbedrohungen betroffene Personen zu schützen;
4. „öffentliches Kommunikationsnetz“ ein öffentliches elektronisches Kommunikationsnetz gemäß § 4 Z 9 TKG 2021;
5. „Kommunikationsdienst“ ein elektronischer Kommunikationsdienst gemäß § 4 Z 4 TKG 2021;
6. „IKT-Produkt“ ein Element oder eine Gruppe von Elementen eines Netz- oder Informationssystems;
7. „IKT-Dienst“ ein Dienst, der vollständig oder überwiegend aus der Übertragung, Speicherung, Abfrage oder Verarbeitung von Informationen mittels Netz- und Informationssystemen besteht;
8. „IKT-Prozess“ jegliche Tätigkeiten, mit denen ein IKT-Produkt oder -Dienst konzipiert, entwickelt, bereitgestellt oder gepflegt werden soll;
9. „Schwachstelle“ eine Schwäche, Anfälligkeit oder Fehlfunktion von IKT-Produkten oder IKT-Diensten, die bei einer Cyberbedrohung ausgenutzt werden kann;
10. „Einrichtung“ eine natürliche Person oder nach dem an ihrem Sitz geltenden nationalen Recht geschaffene und anerkannte juristische Person oder eingetragene Personengesellschaft, die in eigenem Namen Rechte ausüben und Pflichten unterliegen kann;
11. „Leitungsorgan“ eine oder mehrere natürliche Personen oder Verwaltungsorgane, die nach Gesetz, Satzung oder Vertrag zur Führung der Geschäfte einer Einrichtung berufen sind;
12. „DNS-Diensteanbieter“ (Domainnamensystem – DNS) eine Einrichtung, die
 - a) für Internet-Endnutzer öffentlich verfügbare rekursive Dienste zur Auflösung von Domännennamen anbietet, oder
 - b) autoritative Dienste zur Auflösung von Domännennamen zur Nutzung durch Dritte, mit Ausnahme von Root-Namensservern, anbietet;
13. „Namenregister der Domäne oberster Stufe“ oder „TLD-Namenregister“ eine Einrichtung, der eine bestimmte Domäne oberster Stufe (Top Level Domain – TLD) übertragen wurde und die für die Verwaltung der TLD, einschließlich der Registrierung von Domännennamen unterhalb der TLD, sowie für den technischen Betrieb der TLD, einschließlich des Betriebs ihrer Namensserver, der Pflege ihrer Datenbanken und der Verteilung von TLD-Zonendateien über die Namensserver, zuständig ist, unabhängig davon, ob der Betrieb durch die Einrichtung selbst erfolgt oder ausgelagert wird, jedoch mit Ausnahme von Situationen, in denen TLD-Namen von einem Register nur für seine eigenen Zwecke verwendet werden;
14. „Einrichtung, die Domännennamen-Registrierungsdienste erbringt“ ein Registrar oder eine Stelle, die im Namen von Registraren tätig ist, wie etwa Wiederverkäufer oder Anbieter von Datenschutz- oder Proxy-Registrierungsdiensten;
15. „Anbieter digitaler Dienste“ eine juristische Person oder eingetragene Personengesellschaft, die einen digitalen Dienst gemäß § 3 Z 1 des E-Commerce-Gesetzes (ECG), BGBl. I Nr. 152/2001,

erbringt, bei dem es sich um einen Online-Marktplatz oder eine Online-Suchmaschine oder eine Plattform für Dienste sozialer Netzwerke handelt;

16. „Vertrauensdienst“ ein Vertrauensdienst gemäß Art. 3 Z 16 der Verordnung (EU) Nr. 910/2014 über elektronische Identifizierung und Vertrauensdienste für elektronische Transaktionen im Binnenmarkt und zur Aufhebung der Richtlinie 1999/93/EG, ABl. Nr. L 257 vom 28.08.2014 S. 73, in der Fassung der Berichtigung ABl. Nr. L 23 vom 29.01.2015 S. 19;
17. „Vertrauensdiensteanbieter“ ein Vertrauensdiensteanbieter gemäß Art. 3 Z 19 Verordnung (EU) Nr. 910/2014;
18. „qualifizierter Vertrauensdiensteanbieter“ ein qualifizierter Vertrauensdiensteanbieter gemäß Art. 3 Z 20 Verordnung (EU) Nr. 910/2014;
19. „qualifizierte elektronische Signaturerstellungseinheit“ eine qualifizierte elektronische Signaturerstellungseinheit gemäß Art. 3 Z 23 Verordnung (EU) Nr. 910/2014;
20. „qualifizierte elektronische Siegelerstellungseinheit“ eine qualifizierte elektronische Siegelerstellungseinheit gemäß Art. 3 Z 32 Verordnung (EU) Nr. 910/2014;
21. „Konformitätsbewertungsbericht“ ein Konformitätsbewertungsbericht gemäß Art. 20 Abs. 1 Verordnung (EU) Nr. 910/2014;
22. „vertrauenswürdige Systeme eines Vertrauensdiensteanbieters“ Systeme und Produkte, die den Erfordernissen gemäß Art. 24 Abs. 2 lit. e und f Verordnung (EU) Nr. 910/2014 entsprechen;
23. „Anbieter verwalteter Dienste“ (Managed Service Provider) eine Einrichtung, die Dienste im Zusammenhang mit der Installation, der Verwaltung, dem Betrieb oder der Wartung von IKT-Produkten, Netzen, Infrastruktur, Anwendungen oder jeglicher anderer Netz- und Informationssysteme durch Unterstützung oder aktive Verwaltung erbringt, dies entweder in den Räumlichkeiten der Kunden oder aus der Ferne;
24. „Anbieter verwalteter Sicherheitsdienste“ ein Anbieter verwalteter Dienste, der Unterstützung für Tätigkeiten im Zusammenhang mit dem Risikomanagement im Bereich der Cybersicherheit durchführt oder erbringt;
25. „Vertreter“ eine in der Europäischen Union niedergelassene natürliche oder juristische Person, die ausdrücklich benannt wurde, um im Auftrag eines DNS-Diensteanbieters, einer Einrichtung, die Domännennamen-Registrierungsdienste erbringt, eines TLD-Namenregisters, eines Anbieters von Cloud-Computing-Diensten, eines Anbieters von Rechenzentrumsdiensten, eines Betreibers von Inhaltzustellnetzen, eines Anbieters verwalteter Dienste, eines Anbieters verwalteter Sicherheitsdienste oder eines Anbieters von einem Online-Marktplatz, von einer Online-Suchmaschine oder von einer Plattform für Dienste sozialer Netzwerke, der oder die nicht in der Europäischen Union niedergelassen ist, zu handeln, und an die sich eine nationale zuständige Behörde oder ein CSIRT – statt an die Einrichtung – hinsichtlich der Pflichten dieser Einrichtung gemäß diesem Bundesgesetz wenden kann;
26. „Risiko“ das Potenzial für Verluste oder Störungen, die durch einen Cybersicherheitsvorfall verursacht werden, das als eine Kombination des Ausmaßes eines solchen Verlusts oder einer solchen Störung und der Wahrscheinlichkeit des Eintretens des Cybersicherheitsvorfalls zum Ausdruck gebracht wird;
27. „Cyberbedrohung“ ein möglicher Umstand, ein mögliches Ereignis oder eine mögliche Handlung, der/das/die Netz- und Informationssysteme, die Nutzer dieser Systeme und andere Personen schädigen, stören oder anderweitig beeinträchtigen könnte;
28. „erhebliche Cyberbedrohung“ eine Cyberbedrohung, die das Potenzial besitzt, die Netz- und Informationssysteme einer Einrichtung oder der Nutzer solcher Systeme aufgrund ihrer technischen Merkmale erheblich zu beeinträchtigen, indem sie erheblichen materiellen oder immateriellen Schaden verursacht;
29. „Beinahe-Cybersicherheitsvorfall“ (Near Miss) ein Ereignis, das die Verfügbarkeit, Authentizität, Integrität oder Vertraulichkeit gespeicherter, übermittelter oder verarbeiteter Daten oder der Dienste, die über Netz- und Informationssysteme angeboten werden oder zugänglich sind, beeinträchtigt haben könnte, dessen Eintritt jedoch erfolgreich verhindert wurde oder das nicht eingetreten ist;
30. „Cybersicherheitsvorfall“ ein Ereignis, das die Verfügbarkeit, Authentizität, Integrität oder Vertraulichkeit gespeicherter, übermittelter oder verarbeiteter Daten oder der Dienste, die über Netz- und Informationssysteme angeboten werden oder zugänglich sind, beeinträchtigt;
31. „Cybersicherheitsvorfall großen Ausmaßes“ ein Cybersicherheitsvorfall, der eine Störung verursacht, deren Ausmaß die Reaktionsfähigkeit eines Mitgliedstaats der Europäischen Union übersteigt, oder der beträchtliche Auswirkungen auf mindestens zwei Mitgliedstaaten hat;

32. „Innerer Kreis der Operativen Koordinierungsstruktur“ (IKDOK) eine Struktur zur Koordination auf operativer Ebene im Bereich der Cybersicherheit bestehend aus Vertretern des Bundeskanzlers, des Bundesministers für Inneres, der Cybersicherheitsbehörde, des Bundesministers für Landesverteidigung sowie des Bundesministers für europäische und internationale Angelegenheiten;
33. „Operative Koordinierungsstruktur“ (OpKoord) eine Struktur zur Koordination auf operativer Ebene im Bereich der Cybersicherheit bestehend aus dem IKDOK und den Computer-Notfallteams (CSIRTs), die anlassbezogen um zusätzliche Teilnehmer erweitert werden kann;
34. „Kooperationsgruppe“ ein gemäß Art. 14 der Richtlinie (EU) 2022/2555 über Maßnahmen für ein hohes gemeinsames Cybersicherheitsniveau in der Union, zur Änderung der Verordnung (EU) Nr. 910/2014 und der Richtlinie (EU) 2018/1972 sowie zur Aufhebung der Richtlinie (EU) 2016/1148 (NIS-2-Richtlinie), ABl. Nr. L 333 vom 27.12.2022 S. 80, eingesetztes Gremium zur Unterstützung und Erleichterung der strategischen Zusammenarbeit und des Informationsaustauschs zwischen den Mitgliedstaaten der Europäischen Union und zur Stärkung des Vertrauens;
35. „CSIRTs-Netzwerk“ das gemäß Art. 15 NIS-2-Richtlinie errichtete Netzwerk der CSIRTs der Mitgliedstaaten der Europäischen Union;
36. „EU-CyCLONe“ das gemäß Art. 16 NIS-2-Richtlinie zur Unterstützung des koordinierten Managements von Cybersicherheitsvorfällen großen Ausmaßes und Krisen auf operativer Ebene und zur Gewährleistung eines regelmäßigen Austauschs relevanter Informationen zwischen den Mitgliedstaaten und den Organen, Einrichtungen und sonstigen Stellen der Europäischen Union eingerichtete Europäische Netzwerk der Verbindungsorganisationen für Cyberkrisen (European Cyber Crisis Liaison Organisation Network, kurz: EU-CyCLONe);
37. „Überwachungsbeauftragter“ ein Mitarbeiter der Cybersicherheitsbehörde, der für den gemäß § 39 Abs. 3 Z 2 festgelegten Zeitraum die Einhaltung der Risikomanagementmaßnahmen (§ 32) und der Berichtspflichten (§ 34) einer wesentlichen Einrichtung überprüft.

2. Hauptstück

Strukturen und Aufgaben

1. Abschnitt

Zuständige Behörde

Bundesamt für Cybersicherheit

§ 3a. (1) Zuständige Behörde im Sinne dieses Bundesgesetzes ist das Bundesamt für Cybersicherheit (Cybersicherheitsbehörde).

(2) Die Cybersicherheitsbehörde besteht als eine dem Bundesminister für Inneres unmittelbar nachgeordnete organisatorisch außerhalb der Generaldirektion für die öffentliche Sicherheit eingerichtete Behörde mit bundesweiter Zuständigkeit.

(3) Der Direktor sowie sein Stellvertreter haben den zuständigen Ausschüssen des Nationalrats für Auskünfte aus ihrem Aufgabenbereich zur Verfügung zu stehen.

Organisation

§ 3b. (1) An der Spitze der Cybersicherheitsbehörde steht der Direktor.

(2) Zum Direktor sowie zum Stellvertreter kann nur ernannt werden, wer ein abgeschlossenes facheinschlägiges Hochschulstudium (Z 1.12. der Anlage 1 des Beamten-Dienstrechtsgesetzes 1979 – BDG 1979, BGBl. Nr. 333/1979) aufweist sowie zumindest über eine fünfjährige einschlägige Berufserfahrung verfügt. Abweichend von § 7 Abs. 2 zweiter Satz des Ausschreibungsgesetzes 1989 (AusG), BGBl. Nr. 85/1989, hat der Bundesminister für Inneres für die Begutachtungskommission für den Direktor und den Stellvertreter ein Mitglied zu bestellen. Der für Telekommunikation zuständige Bundesminister hat das weitere Mitglied zu bestellen, wobei dabei auf die Geschlechterparität Bedacht zu nehmen ist.

(3) Die Cybersicherheitsbehörde hat ihren Sitz in Wien. Zur Durchführung einzelner Aufgaben gemäß § 4 Abs. 1 kann der Direktor der Cybersicherheitsbehörde Außenstellen einrichten. Der Direktor kann zudem anordnen, dass ihm von den Außenstellen laufend oder zu bestimmten Zeitpunkten direkt über den Fortgang einer Angelegenheit zu berichten ist.

(4) Die Zahl der Organisationseinheiten in der Cybersicherheitsbehörde und in den Außenstellen sowie die Aufteilung der Geschäfte in diesen sind in einer vom Direktor zu erlassenden Geschäftseinteilung im Interesse einer raschen und zweckmäßigen Geschäftsbehandlung festzulegen.

(5) Der Direktor hat durch Ausbildung und berufsbegleitende Fortbildung der Mitarbeiter der Cybersicherheitsbehörde deren Qualifikation sicherzustellen.

(6) Weisungen des Bundesministers für Inneres an den Direktor der Cybersicherheitsbehörde sind schriftlich zu erteilen und zu begründen sowie in einem halbjährlichen Bericht bis spätestens sechs Monate nach Ende des Berichtszeitraums zu veröffentlichen.

(7) Beamte und Vertragsbedienstete, die am Tag vor Inkrafttreten dieses Bundesgesetzes dem Personalstand des Bundesministeriums für Inneres angehören und die gemäß der zu diesem Zeitpunkt geltenden Geschäftseinteilung der Organisationseinheit „Netz- und Informationssystemsicherheit“ zugewiesen sind, sind ab Inkrafttreten dieses Bundesgesetzes der Cybersicherheitsbehörde zur dauernden Dienstleistung zugewiesen. Die Bestimmungen der Reisegebührenvorschrift 1955, BGBl. Nr. 133/1955, sind auf diese Zuweisungen von Beamten nicht anzuwenden.

Aufgaben der Cybersicherheitsbehörde

§ 4. (1) Die Cybersicherheitsbehörde hat folgende Aufgaben wahrzunehmen:

1. Koordination der Erstellung der Österreichischen Strategie für Cybersicherheit (ÖSCS) gemäß § 15;
2. Leitung der Koordinierungsstrukturen (CSS, IKDOK und OpKoord) gemäß den §§ 12 bis 14;
3. Regelmäßige Erstellung und Weiterleitung von Lagebildern und zusätzlich relevanter Informationen gemäß den §§ 12 bis 14;
4. Erstellung, Analyse und Weitergabe von zur Gewährleistung der Sicherheit von Netz- und Informationssystemen relevanten Informationen zur Vorbeugung von Cybersicherheitsvorfällen;
5. Ausübung der Funktion der nationalen Behörde für das Management von Cybersicherheitsvorfällen großen Ausmaßes gemäß § 16;
6. Ausübung der Funktion des Nationalen Koordinierungszentrums für Cybersicherheit gemäß § 6;
7. Vertretung Österreichs in EU-weiten und internationalen Gremien betreffend die Gewährleistung eines hohen Cybersicherheitsniveaus von Netz- und Informationssystemen, insbesondere in der Kooperationsgruppe, dem EU-CyCLONe sowie dem Europäischen Kompetenznetz und Zentrum für Cybersicherheit (ECCC), sofern nicht der Wirkungsbereich anderer Bundesminister betroffen ist;
8. Konsultation und Zusammenarbeit mit den zuständigen Behörden anderer Mitgliedstaaten der Europäischen Union gemäß § 22;
9. Betrieb der zentralen Anlaufstelle gemäß § 5;
10. Betrieb des GovCERT gemäß § 8 Abs. 4;
11. Ermächtigung von CSIRTs gemäß § 8 Abs. 2 und 3;
12. Zulassung unabhängiger Prüfer gemäß § 7 Abs. 2 und 3;
13. Ausübung der Aufsichts- und Durchsetzungsmaßnahmen gegenüber wesentlichen und wichtigen Einrichtungen gemäß den §§ 38 und 39;
14. Entgegennahme, Analyse und Weiterleitung von Meldungen gemäß den §§ 34, 37 sowie 8 Abs. 1 Z 7;
15. Betrieb von IKT-Lösungen gemäß den §§ 17, 18 und 19.

(2) Angelegenheiten, die unter die Verordnung (EU) 2022/2554 über die digitale operationale Resilienz im Finanzsektor und zur Änderung der Verordnungen (EG) Nr. 1060/2009, (EU) Nr. 648/2012, (EU) Nr. 600/2014, (EU) Nr. 909/2014 und (EU) 2016/1011, ABl. Nr. L 333 vom 27.12.2022 S 1, fallen, bleiben von diesem Bundesgesetz unberührt.

(3) Der Bundesminister für Inneres hat den halbjährlichen Bericht zur Cybersicherheit gemeinsam mit einer Übersicht der eingelangten Meldungen gemäß den §§ 34 und 37 einschließlich der gemäß § 34 Abs. 9 übermittelten Informationen, Meldungen gemäß § 21 Abs. 2, Informationen gemäß § 39 Abs. 9 sowie die Höhe der gemäß § 8 Abs. 6 ersetzten Aufwendungen dem Nationalrat und dem Bundesrat bis spätestens sechs Monate nach Ende des jeweiligen Berichtszeitraums vorzulegen.

(4) Vor Beginn der Tätigkeit müssen sich sämtliche Mitarbeiter der Cybersicherheitsbehörde, einschließlich des Direktors sowie seines Stellvertreters, einer Sicherheitsüberprüfung gemäß den §§ 55 bis 55b des Sicherheitspolizeigesetzes (SPG), BGBl. Nr. 566/1991, für den Zugang zu geheimer

Information unterziehen. Die Sicherheitsüberprüfungen sind alle drei Jahre zu wiederholen. § 55a Abs. 4 dritter und vierter Satz SPG gilt.

Zentrale Anlaufstelle der Cybersicherheitsbehörde

§ 5. (1) Die Cybersicherheitsbehörde hat eine zentrale Anlaufstelle zu betreiben, die als operative Verbindungsstelle der Gewährleistung der Sicherheit von Netz- und Informationssystemen, der grenzüberschreitenden Zusammenarbeit und Kommunikation mit den zuständigen Stellen in den anderen Mitgliedstaaten der Europäischen Union sowie der Kooperationsgruppe, dem EU-CyCLONe und dem CSIRTs-Netzwerk dient.

(2) Die zentrale Anlaufstelle hat

1. eingehende Meldungen und Anfragen unmittelbar an die Mitglieder des IKDOK und die CSIRTs weiterzuleiten, soweit dies zur Erfüllung einer gesetzlich übertragenen Aufgabe des jeweiligen Mitglieds des IKDOK oder des CSIRTs erforderlich ist;
2. einen Auszug aus dem Register der Einrichtungen gemäß § 29 Abs. 5 an die ENISA weiterzuleiten;
3. die zentralen Anlaufstellen in anderen Mitgliedstaaten der Europäischen Union zu unterrichten, wenn ein Cybersicherheitsvorfall einen oder mehrere andere Mitgliedstaaten betrifft (§ 34 Abs. 5).

Nationales Koordinierungszentrum für Cybersicherheit

§ 6. (1) Die Cybersicherheitsbehörde hat die Funktion als nationales Koordinierungszentrum für Cybersicherheit auszuüben. In dieser Funktion hat sie insbesondere folgende Aufgaben wahrzunehmen:

1. den Betrieb eines nationalen Koordinierungszentrums gemäß der Verordnung (EU) 2021/887 zur Einrichtung des Europäischen Kompetenzzentrums für Industrie, Technologie und Forschung im Bereich der Cybersicherheit und des Netzwerks nationaler Koordinierungszentren, ABl. Nr. L 202 vom 08.06.2021 S. 1;
2. die Koordination der öffentlich-privaten Zusammenarbeit im Bereich der Cybersicherheit;
3. die Koordination der Erstellung eines halbjährlichen Berichts zur Cybersicherheit und Vorlage an den Bundesminister für Inneres;
4. die Dokumentation und Bereitstellung von Informationen zum Thema Cybersicherheit für die Öffentlichkeit;
5. die Organisation und Durchführung von Kampagnen zur Bewusstseinsbildung und Sensibilisierung der Öffentlichkeit, insbesondere für Cyberbedrohungen sowie zur Stärkung und Erweiterung von Fähigkeiten und Kenntnissen im Bereich der Cybersicherheit;
6. die Bereitstellung von generellen Empfehlungen und Leitlinien zur Prävention von Cybersicherheitsvorfällen und Reduktion von Risiken;
7. die regelmäßige Veranstaltung von und Mitwirkung an Cybersicherheitsübungen;
8. die Durchführung und Unterstützung von Risikobewertungen, insbesondere in den in § 2 genannten Sektoren und bei EU-weit koordinierten Risikobewertungen, gegebenenfalls in Zusammenarbeit mit den maßgeblichen Interessenträgern;
9. die Durchführung von Analysen über Informations- und Kommunikationstechnik und themenspezifische Bewertung der von technischen Innovationen zu erwartenden gesellschaftlichen, rechtlichen, wirtschaftlichen und regulatorischen Auswirkungen auf die Cybersicherheit;
10. die Durchführung von langfristigen strategischen Analysen von Cyberbedrohungen und Cybersicherheitsvorfällen, gegebenenfalls in Zusammenarbeit mit maßgeblichen Interessenträgern;
11. die Beratung der zuständigen Bundesminister und öffentlichen Einrichtungen zum Forschungs- und Förderbedarf und zu den Forschungs- und Förderprioritäten im Bereich Cybersicherheit;
12. die Verfolgung von Entwicklungen und gegebenenfalls Mitarbeit an der Er- oder Überarbeitung von Normen mit Bezug auf Cybersicherheit;
13. die Mitwirkung und Teilnahme an nationalen, europäischen und internationalen Forschungs- und Förderprojekten und -programmen auf dem Gebiet der Cybersicherheit.

(2) Anträge von Einrichtungen auf Aufnahme in die Europäische Kompetenzgemeinschaft gemäß Art. 7 Abs. 1 lit. i und Abs. 4 der Verordnung (EU) 2021/887 sind von der Verpflichtung zur Entrichtung von Gebühren gemäß dem Gebührengesetz 1957 (GebG), BGBl. Nr. 267/1957, befreit. Für

Amtshandlungen im Zusammenhang mit diesen Anträgen sind Verwaltungsabgaben des Bundes nicht zu entrichten. Diese Anträge sind in der von der Cybersicherheitsbehörde vorgesehenen Form zu stellen.

2. Abschnitt

Unabhängige Stellen und unabhängige Prüfer

Unabhängige Stellen und unabhängige Prüfer

§ 7. (1) Eine unabhängige Stelle ist eine juristische Person oder eine eingetragene Personengesellschaft mit Niederlassung in Österreich oder in einem anderen Mitgliedstaat der Europäischen Union, die sich zur Prüfung der Umsetzung der Risikomanagementmaßnahmen gemäß § 33 Abs. 2 zumindest eines unabhängigen Prüfers gemäß Abs. 2 bedient, oder eine natürliche Person, die die Tätigkeit als unabhängiger Prüfer selbständig ausübt.

(2) Auf Antrag ist eine natürliche Person von der Cybersicherheitsbehörde als unabhängiger Prüfer zuzulassen, wenn sie

1. über ein österreichisches Reifeprüfungszeugnis, ein österreichisches Diplomprüfungszeugnis, ein österreichisches Zeugnis über die Berufsreifeprüfung, ein aufgrund völkerrechtlicher Vereinbarung gleichwertiges Zeugnis oder eine einschlägige berufliche Qualifikation verfügt,
2. über eine facheinschlägige und durchgängige mindestens dreijährige Berufserfahrung im Ausmaß von zumindest zwanzig Wochenstunden im Bereich der Cybersicherheit, die durch Zeugnisse gemäß § 39 des Angestelltengesetzes, BGBl. Nr. 292/1921, oder in gleichwertiger Form nachzuweisen ist, verfügt und
3. gegenüber der Cybersicherheitsbehörde ihre Eignung zur Prüfung der Umsetzung der Risikomanagementmaßnahmen durch ausreichende theoretische Fachkenntnisse sowie praktische Fähigkeiten in organisatorischer und technischer Hinsicht im Rahmen einer Eignungsprüfung nachweist.

(3) Die Cybersicherheitsbehörde hat die Zulassung gemäß Abs. 2 zu entziehen, wenn

1. der unabhängige Prüfer innerhalb der letzten fünf Jahre nicht zumindest eine Prüfung gemäß § 33 Abs. 2 durchgeführt hat oder
2. die Eignung des unabhängigen Prüfers gemäß Abs. 2 Z 3 nicht mehr gegeben ist.

Nach einer rechtskräftigen Entziehung der Zulassung kann die betroffene Person erst nach Ablauf eines Jahres einen neuerlichen Antrag auf Zulassung stellen.

(4) Die Cybersicherheitsbehörde hat eine Liste mit den Kontaktdaten der unabhängigen Prüfer zu führen und wesentlichen und wichtigen Einrichtungen in geeigneter Weise zur Verfügung zu stellen.

(5) Unabhängige Prüfer sind zur vertraulichen Behandlung der im Rahmen der Prüfung der Umsetzung der Risikomanagementmaßnahmen bekanntgewordenen Informationen, deren Geheimhaltung im Interesse der jeweiligen geprüften Einrichtungen geboten ist, verpflichtet. Dies gilt auch für sonstige Personen, denen im Zuge ihrer Tätigkeit bei einer unabhängigen Stelle solche Informationen bekanntwerden.

(6) Die Cybersicherheitsbehörde kann mit Verordnung

1. nähere Regelungen zu den erforderlichen Fachkenntnissen und Fähigkeiten gemäß Abs. 2 Z 3, einschließlich der Form der Eignungsprüfung, und
2. Pauschalsätze für Verwaltungsabgaben für die Zulassung als unabhängiger Prüfer, die dem durchschnittlichen Aufwand der jeweiligen Zulassung entsprechen,

festlegen.

3. Abschnitt

Computer-Notfallteams

Zweck und Aufgaben der Computer-Notfallteams

§ 8. (1) Computer-Notfallteams (CSIRTs) im Sinne dieses Bundesgesetzes haben zur Gewährleistung der Sicherheit von Netz- und Informationssystemen folgende Aufgaben wahrzunehmen:

1. die Überwachung und die Analyse von Cyberbedrohungen, Schwachstellen und Cybersicherheitsvorfällen auf nationaler Ebene und gegebenenfalls die Unterstützung betroffener wesentlicher und wichtiger Einrichtungen hinsichtlich der Überwachung ihrer Netz- und Informationssysteme in Echtzeit oder nahezu in Echtzeit;

2. die Ausgabe von Frühwarnungen und Alarmmeldungen sowie die Bekanntmachung und die Weitergabe von Informationen über Cyberbedrohungen, Schwachstellen und Cybersicherheitsvorfälle an wesentliche und wichtige Einrichtungen sowie an zuständige Behörden und andere einschlägige Interessenträger in Echtzeit oder nahezu in Echtzeit;
3. die Reaktion auf Cybersicherheitsvorfälle und gegebenenfalls die Unterstützung betreffender wesentlicher und wichtiger Einrichtungen bei deren Bewältigung;
4. die Erhebung und die Analyse forensischer Daten sowie die dynamische Analyse von Risiken und Cybersicherheitsvorfällen sowie die Lagebeurteilung im Hinblick auf die Cybersicherheit;
5. die Vornahme einer proaktiven Überprüfung der Netz- und Informationssysteme einer ersuchenden wesentlichen oder wichtigen Einrichtung im Hinblick auf Schwachstellen mit potenziell signifikanten Auswirkungen (Schwachstellenscan);
6. die Teilnahme am CSIRTs-Netzwerk (§ 3 Z 35) und die auf Gegenseitigkeit beruhende Unterstützung anderer Mitglieder des CSIRTs-Netzwerks;
7. die Entgegennahme von Meldungen gemäß den §§ 34 und 37;
8. die Teilnahme an Peer Reviews gemäß § 23.

(2) Die Cybersicherheitsbehörde hat bei Erfüllung der Voraussetzungen gemäß § 9 eine Einrichtung zur Wahrnehmung der Aufgaben gemäß Abs. 1 sowie § 11 Abs. 1 zu ermächtigen (nationales CSIRT). Das nationale CSIRT ist zur proaktiven nicht intrusiven Überprüfung öffentlich zugänglicher Netz- und Informationssysteme berechtigt. Eine solche Überprüfung darf keine nachteiligen Auswirkungen auf das Funktionieren der Dienste der betroffenen wesentlichen oder wichtigen Einrichtungen haben. Werden bei einer solchen Überprüfung anfällige oder unsicher konfigurierte Netz- und Informationssysteme ermittelt, sind die jeweiligen Einrichtungen darüber zu unterrichten.

(3) Die Cybersicherheitsbehörde kann bei Bedarf für jeden Sektor (§ 2) eine Einrichtung zur Wahrnehmung der Aufgaben gemäß Abs. 1 ermächtigen (sektorspezifisches CSIRT). Solange kein sektorspezifisches CSIRT besteht, hat das nationale CSIRT die Aufgaben des jeweiligen sektorspezifischen CSIRTs für den jeweiligen Sektor wahrzunehmen.

(4) Das bei der Cybersicherheitsbehörde eingerichtete GovCERT hat als sektorspezifisches CSIRT (Abs. 3) die Aufgaben gemäß Abs. 1 für Einrichtungen der öffentlichen Verwaltung (§ 24 Abs. 3) wahrzunehmen. Solange kein nationales CSIRT besteht, hat das GovCERT die Aufgaben des nationalen CSIRTs (Abs. 2 und 3) wahrzunehmen.

(5) Die Cybersicherheitsbehörde hat die Entscheidung über die Ermächtigung des nationalen CSIRTs (Abs. 2) sowie sektorspezifischer CSIRTs (Abs. 3) in einer Weise kundzumachen, die geeignet scheint, einen möglichst weiten Adressatenkreis zu erreichen.

(6) Dem nationalen CSIRT und den sektorspezifischen CSIRTs gebührt vom Bund ein Ersatz für die bei Erfüllung ihrer Aufgaben gemäß Abs. 1 sowie § 11 Abs. 1 entstandenen Kosten, deren Höhe auf Grundlage einer transparenten internen Kostenrechnung unter Zugrundelegung der Prinzipien der Sparsamkeit, Wirtschaftlichkeit und Zweckmäßigkeit nach dem Grundsatz der Kostendeckung festzulegen ist.

(7) Sektorspezifische CSIRTs (Abs. 3 und 4) sind ermächtigt, für Zwecke des Abs. 1 Z 2 und 4 auf Ersuchen einer wesentlichen oder wichtigen Einrichtung Daten gemäß § 17 Abs. 2 zweiter Satz, die durch eine bei dieser Einrichtung eingerichtete IKT-Lösung gemäß § 17 Abs. 2 erster Satz gewonnen wurden, zu analysieren.

(8) Die CSIRTs haben mit sektorspezifischen oder sektorübergreifenden Zusammenschlüssen wesentlicher und wichtiger Einrichtungen zusammenzuarbeiten und mit diesen gemäß § 36 gegebenenfalls einschlägige Informationen auszutauschen.

(9) Die CSIRTs sind ermächtigt, Kooperationsbeziehungen mit CSIRTs und gleichwertigen Stellen oder Sicherheitsdienstleistern in Drittländern aufzunehmen. Es sind einschlägige Regeln und Verfahren für den wirksamen, effizienten und sicheren Informationsaustausch, einschließlich des Traffic Light Protocol, zu verwenden.

(10) Die Cybersicherheitsbehörde hat der Europäischen Kommission unverzüglich die Identität der CSIRTs gemäß den Abs. 2 bis 4 und des als Koordinator gemäß § 11 Abs. 1 benannten CSIRTs, ihre jeweiligen Aufgaben in Bezug auf wesentliche und wichtige Einrichtungen sowie allfällige Änderungen dieser Angaben mitzuteilen.

(11) CSIRTs können die Aufgaben gemäß Abs. 1 Z 2 bis 4 und Z 7 auch gegenüber sonstigen Einrichtungen oder Personen wahrnehmen, sofern diese von einem Risiko oder einem Cybersicherheitsvorfall betroffen sind.

(12) Die Cybersicherheitsbehörde ist verpflichtet, die Ermächtigung gemäß den Abs. 2 und 3 zu widerrufen, wenn eine für die Erteilung der Ermächtigung erforderliche Voraussetzung gemäß § 9 Abs. 1 nicht mehr gegeben ist.

Anforderungen und Eignung von CSIRTs

§ 9. (1) Die CSIRTs haben die zur Erfüllung ihrer Aufgaben erforderlichen technischen und organisatorischen Fähigkeiten aufzuweisen und müssen zur Gewährleistung einer angemessenen Personalausstattung über ausreichende Ressourcen und geeignetes Personal verfügen. Die CSIRTs haben jedenfalls folgende Anforderungen zu erfüllen:

1. ihre Kommunikationskanäle weisen einen hohen Grad an Sicherheit, Belastbarkeit und Verfügbarkeit auf, indem punktuellen Ausfällen vorgebeugt und mehrere Kanäle bereitgestellt werden, damit sie jederzeit erreichbar bleiben und die Möglichkeit besteht, proaktiv mit anderen Kontakt aufzunehmen; sie legen die Kommunikationskanäle genau fest und machen sie den wesentlichen und wichtigen Einrichtungen, sonstigen Einrichtungen sowie den Kooperationspartnern bekannt;
2. sie verfügen über ein geeignetes System zur Verwaltung und Weiterleitung von Anfragen, insbesondere über ein für den effizienten Informationsaustausch geeignetes System;
3. sie stellen die Vertraulichkeit und Vertrauenswürdigkeit ihrer Tätigkeiten sicher;
4. sie verfügen über entsprechend geschultes Personal und können hinsichtlich der Ausstattung eine ständige Bereitschaft ihrer Dienste gewährleisten;
5. sie verfügen über Redundanzsysteme und Ausweicharbeitsräume, um die Kontinuität ihrer Dienste sicherzustellen;
6. sie setzen Risikomanagementmaßnahmen gemäß § 32 um und melden erhebliche Cybersicherheitsvorfälle gemäß § 34 der Cybersicherheitsbehörde;
7. ihre Mitarbeiter müssen sich einer Sicherheitsüberprüfung nach den §§ 55 ff SPG für den Zugang zu geheimer Information unterzogen haben. Die Sicherheitsüberprüfung ist alle fünf Jahre zu wiederholen;
8. nachweisliche Unterstützung des jeweiligen Sektors (§ 2), wenn es sich um ein CSIRT gemäß § 8 Abs. 3 handelt.

(2) CSIRTs gemäß § 8 Abs. 2 und 3 haben Änderungen hinsichtlich jener Umstände, die Voraussetzung für die Erteilung der Ermächtigung waren, unverzüglich der Cybersicherheitsbehörde anzuzeigen.

(3) Zur Wahrnehmung ihrer gesetzlichen Aufgaben sind die CSIRTs verpflichtet, Kooperationsbeziehungen mit einschlägigen Interessenträgern des Privatsektors zu pflegen. Zur Erleichterung dieser Zusammenarbeit haben die CSIRTs die Annahme und Anwendung gemeinsamer oder standardisierter Vorgehensweisen, Klassifizierungssysteme und Taxonomien für

1. die Verfahren zur Bewältigung von Cybersicherheitsvorfällen,
2. das Krisenmanagement und
3. die koordinierte Offenlegung von Schwachstellen gemäß § 11 Abs. 1

zu fördern.

(4) Mitarbeiter von CSIRTs sind über bekanntgewordene Tatsachen und Erkenntnisse, die im Rahmen der Wahrnehmung ihrer Aufgaben nach diesem Bundesgesetz auftreten und deren Geheimhaltung im Interesse der jeweiligen geprüften Einrichtungen geboten ist, zur Geheimhaltung verpflichtet.

Aufsicht

§ 10. (1) CSIRTs gemäß § 8 Abs. 2 und 3 unterliegen hinsichtlich ihrer Tätigkeit der Aufsicht der Cybersicherheitsbehörde.

(2) Die Cybersicherheitsbehörde kann in Ausübung ihres Aufsichtsrechts den CSIRTs allgemeine Weisungen oder Weisungen im Einzelfall erteilen.

(3) Weisungen an die CSIRTs sind schriftlich zu erteilen und zu begründen. Eine aus besonderen Gründen, insbesondere wegen Gefahr im Verzug, vorerst mündlich erteilte Weisung ist unverzüglich schriftlich nachzureichen.

(4) Die CSIRTs haben der Cybersicherheitsbehörde alle zur Ausübung ihres Aufsichtsrechts erforderlichen Auskünfte zu erteilen und die hierfür notwendigen Unterlagen zu übermitteln.

(5) Die CSIRTs haben der Cybersicherheitsbehörde jeweils einen jährlichen Bericht über die gemäß § 8 Abs. 1 wahrgenommenen Aufgaben bis zum Ablauf des auf das Berichtsjahr folgenden Kalendermonats zu erstatten, die die Berichte innerhalb einer angemessenen Frist zusammengefasst an den Bundesminister für Inneres weiterzuleiten hat. Der Bundesminister für Inneres ist verpflichtet, diesen Bericht dem Nationalrat zu übermitteln.

(6) Die Cybersicherheitsbehörde ist ermächtigt, jederzeit zu überprüfen, ob die Voraussetzungen für die Erteilung der Ermächtigung gemäß § 8 Abs. 2 und 3 noch gegeben sind und die Verpflichtungen gemäß § 9 eingehalten werden. Die Cybersicherheitsbehörde kann Anordnungen zur Behebung von Mängeln treffen, wobei diesen Anordnungen unverzüglich zu entsprechen ist. Werden die Aufgaben gemäß § 8 Abs. 1 nicht ordnungsgemäß besorgt oder wird gegen die Verpflichtungen gemäß § 9 verstoßen, kann die Cybersicherheitsbehörde den Ausschluss bestimmter Personen von dieser Tätigkeit anordnen.

(7) Die Cybersicherheitsbehörde kann die Ermächtigung gemäß § 8 Abs. 2 und 3 widerrufen, wenn ein CSIRT eine Weisung gemäß Abs. 2 nicht befolgt oder eine Auskunft gemäß Abs. 4 nicht erteilt.

Koordinierte Offenlegung von Schwachstellen

§ 11. (1) Das nationale CSIRT (§ 8 Abs. 2) hat die Offenlegung von Schwachstellen zu koordinieren. Es fungiert dabei als vertrauenswürdiger Vermittler und erleichtert erforderlichenfalls die Interaktion zwischen der eine Schwachstelle meldenden natürlichen oder juristischen Person und dem Hersteller oder Anbieter der potenziell gefährdeten IKT-Produkte oder IKT-Dienste auf Ersuchen einer der beiden Seiten. Zu den Aufgaben des als Koordinator benannten nationalen CSIRTs gehört es insbesondere,

1. die betreffenden Einrichtungen zu ermitteln und zu kontaktieren,
2. die natürlichen oder juristischen Personen, die eine Schwachstelle melden, zu unterstützen,
3. die Zeitpläne für die Offenlegung auszuhandeln und das Vorgehen bei Schwachstellen, die mehrere Einrichtungen betreffen, zu koordinieren, sowie
4. gegebenenfalls die sektorspezifischen CSIRTs zu informieren.

(2) Natürliche oder juristische Personen können dem nationalen CSIRT eine Schwachstelle auf Wunsch anonym melden. Das nationale CSIRT hat sicherzustellen, dass in Bezug auf die gemeldete Schwachstelle sorgfältige Folgemaßnahmen durchgeführt werden können. Die Anonymität der die Schwachstelle meldenden natürlichen oder juristischen Person ist zu wahren.

(3) Wenn die gemeldete Schwachstelle erhebliche Auswirkungen auf Einrichtungen in mehreren Mitgliedstaaten der Europäischen Union haben könnte, hat das nationale CSIRT mit den anderen als Koordinatoren benannten CSIRTs innerhalb des CSIRTs-Netzwerks zusammenzuarbeiten.

(4) Über Schwachstellen, die eine qualifizierte elektronische Signaturerstellungseinheit, eine qualifizierte elektronische Siegelerstellungseinheit oder die vertrauenswürdigen Systeme eines Vertrauensdiensteanbieters betreffen, hat das nationale CSIRT unverzüglich, in jedem Fall aber innerhalb von 24 Stunden nach Kenntnisnahme der Schwachstelle, die Aufsichtsstelle gemäß § 12 des Signatur- und Vertrauensdienstegesetzes (SVG), BGBl. I Nr. 50/2016, zu informieren.

4. Abschnitt

Nationale Koordinierung

Cyber Sicherheit Steuerungsgruppe (CSS)

§ 12. (1) Die Cyber Sicherheit Steuerungsgruppe (CSS) wird als das zentrale strategisch koordinierende Organ der Cybersicherheit in Österreich unter der Leitung der Cybersicherheitsbehörde eingerichtet.

(2) Der CSS kommen folgende Aufgaben zu:

1. die Mitwirkung bei der Entwicklung und die Koordination der ÖSCS gemäß § 15 Abs. 1;
2. die Beobachtung der Umsetzung der ÖSCS (Monitoring);
3. die Mitwirkung bei der Erstellung eines halbjährlichen Berichts zur Cybersicherheit;
4. die Erstellung einer eigenen Geschäftsordnung.

(3) Die CSS setzt sich aus je einem zur selbständigen Behandlung von Angelegenheiten ermächtigten fachkundigen Vertreter der dem Nationalen Sicherheitsrat angehörenden Bundesminister (§ 3 Abs. 1 des Bundesgesetzes über die Errichtung eines Nationalen Sicherheitsrates, BGBl. I Nr. 122/2001) sowie der für Telekommunikation und Digitalisierung zuständigen Bundesminister

zusammen. Ein Vertreter der Präsidentschaftskanzlei ist berechtigt, an den Sitzungen der CSS mit beratender Stimme teilzunehmen.

(4) Bei Bedarf kann die CSS um Vertreter von Einrichtungen im Sektor der öffentlichen Verwaltung erweitert werden, insbesondere wenn ihr Wirkungsbereich von Maßnahmen der ÖSCS betroffen ist.

Innerer Kreis der Operativen Koordinierungsstruktur (IKDOK)

§ 13. (1) Zur Erörterung und Aktualisierung des von der Cybersicherheitsbehörde erstellten Lagebildes über Risiken, Cyberbedrohungen und Cybersicherheitsvorfälle sowie zur Erörterung der Erkenntnisse, die gemäß § 17 Abs. 2 und 3 gewonnen wurden, wird der IKDOK eingerichtet.

(2) Im Rahmen des IKDOK können klassifizierte Informationen zwischen den Teilnehmern zur Wahrnehmung der Aufgaben nach Maßgabe ihrer Zuständigkeiten ausgetauscht werden.

Operative Koordinierungsstruktur (OpKoord)

§ 14. (1) Zur Erörterung eines gesamtheitlichen Lagebildes wird eine Operative Koordinierungsstruktur („OpKoord“) eingerichtet. Diese setzt sich aus dem IKDOK und den CSIRTs zusammen.

(2) Die OpKoord kann um Vertreter von wesentlichen und wichtigen Einrichtungen sowie sonstigen Einrichtungen erweitert werden, wenn deren Wirkungsbereich von einem Cybersicherheitsvorfall, einer Cyberbedrohung oder einem Beinahe-Vorfall betroffen ist („erweiterte OpKoord“).

(3) Alle Teilnehmer der OpKoord sind, soweit es sich nicht um die im IKDOK vertretenen Einrichtungen handelt, über die ihnen aufgrund der Teilnahme bekanntgewordenen Informationen zur Geheimhaltung verpflichtet, sofern dies für eine Sitzung oder einzelne Umstände nicht anders beschlossen wurde.

(4) Die Teilnehmer des IKDOK können einvernehmlich nähere Regelungen über das Zusammenwirken der Teilnehmer des IKDOK und der OpKoord, insbesondere über die Einberufung von Sitzungen und die Zusammensetzung, in einer Geschäftsordnung treffen.

(5) Die an der OpKoord teilnehmenden Einrichtungen dürfen die zum Zweck der Organisation der OpKoord und die zur Wahrnehmung der Aufgaben gemäß Abs. 1 erforderlichen personenbezogenen Daten verarbeiten.

Nationale Cybersicherheitsstrategie

§ 15. (1) Die Cybersicherheitsbehörde hat die Erstellung der Österreichischen Strategie für Cybersicherheit (ÖSCS) unter Einbindung der CSS zu koordinieren. Die ÖSCS wird von der Bundesregierung erlassen.

(2) Die ÖSCS bestimmt insbesondere die strategischen Ziele, die zur Erreichung dieser Ziele erforderlichen Ressourcen sowie angemessene politische und regulatorische Maßnahmen zur Erreichung und Aufrechterhaltung eines hohen Cybersicherheitsniveaus im Bundesgebiet.

(3) Die ÖSCS hat jedenfalls zu enthalten:

1. Ziele und Prioritäten der nationalen Cybersicherheitsstrategie, die insbesondere die in den **Anlagen 1 und 2** angeführten Sektoren abdecken;
2. einen Steuerungsrahmen zur Verwirklichung der unter Z 1 dieses Absatzes genannten Ziele und Prioritäten, der die in Abs. 2 genannten Konzepte umfasst;
3. einen Steuerungsrahmen, in dem die Aufgaben und Zuständigkeiten der jeweiligen Interessenträger auf nationaler Ebene klargestellt, die Zusammenarbeit und Koordination auf nationaler Ebene zwischen der Cybersicherheitsbehörde, der zentralen Anlaufstelle und den CSIRTs sowie die Koordination und Zusammenarbeit zwischen diesen Stellen und nach sektorspezifischen Rechtsakten der Europäischen Union zuständigen Behörden untermauert werden;
4. einen Maßnahmenkatalog zur Förderung der Achtung des Völkerrechts, Stärkung freiwilliger Normen, Regeln und Prinzipien des verantwortungsvollen Staatenverhaltens sowie der Vertrauensbildung im Cyberraum im Wege der Cyberdiplomatie auf bilateraler und multilateraler Ebene;
5. einen Plan zur Umsetzung der Aufgaben des Bundesministers für europäische und internationale Angelegenheiten im Bereich der Cyber-Außenpolitik;
6. einen Mechanismus zur Ermittlung von relevanten Anlagen und eine Bewertung der nationalen Cybersicherheitsrisiken;

7. die Bestimmung von Maßnahmen zur Gewährleistung der Vorsorge, Reaktionsfähigkeit und Wiederherstellung bei Cybersicherheitsvorfällen, einschließlich der Zusammenarbeit zwischen dem öffentlichen und dem privaten Sektor;
 8. eine Liste der verschiedenen Behörden und Interessenträger, die an der Umsetzung der nationalen Cybersicherheitsstrategie beteiligt sind;
 9. einen politischen Rahmen für eine verstärkte Koordinierung zwischen der Cybersicherheitsbehörde und jener Behörde, die in Umsetzung des Art. 9 der Richtlinie (EU) 2022/2557 über die Resilienz kritischer Einrichtungen und zur Aufhebung der Richtlinie 2008/114/EG des Rates, ABl. Nr. L 333 vom 27.12.2022 S. 164, national als zuständige Behörde benannt oder eingerichtet wurde, zum Zweck des Informationsaustauschs über Risiken, Cyberbedrohungen und Cybersicherheitsvorfälle sowie über nicht cyberbezogene Risiken, Bedrohungen und Sicherheitsvorfälle und für die Wahrnehmung von Aufsichtsaufgaben;
 10. einen Plan, einschließlich erforderlicher Maßnahmen zur Steigerung des allgemeinen Grads der Sensibilisierung für Cybersicherheit bei Bürgerinnen und Bürgern;
 11. einen nationalen Plan für die Reaktion auf Cybersicherheitsvorfälle großen Ausmaßes gemäß § 16 Abs. 3;
 12. einen Plan zum langfristigen Kompetenzaufbau im Bereich der Cybersicherheit unter Berücksichtigung insbesondere von Aspekten der Forschung, Technologie und Innovation;
 13. einen Plan für Maßnahmen zur Unterstützung des Kapazitätenaufbaus von Drittstaaten in Schwerpunktregionen im Bereich der Cybersicherheit.
- (4) Im Rahmen der ÖSCS sind insbesondere Konzepte enthalten
1. für die Cybersicherheit in der Lieferkette für IKT-Produkte und IKT-Dienste, die von Einrichtungen für die Erbringung ihrer Dienste genutzt werden,
 2. für die Aufnahme und Spezifikation cybersicherheitsbezogener Anforderungen an IKT-Produkte und IKT-Dienste bei der Vergabe öffentlicher Aufträge, einschließlich hinsichtlich der Zertifizierung der Cybersicherheit, der Verschlüsselung und der Nutzung quelloffener Cybersicherheitsprodukte,
 3. für das Vorgehen bei Schwachstellen, das die Förderung und Erleichterung der koordinierten Offenlegung von Schwachstellen gemäß § 11 Abs. 1 umfasst,
 4. im Zusammenhang mit der Aufrechterhaltung der allgemeinen Verfügbarkeit, Integrität und Vertraulichkeit des öffentlichen Kerns des offenen Internets,
 5. zur Förderung der Entwicklung und Integration einschlägiger fortgeschrittener Technologien, damit Risikomanagementmaßnahmen im Bereich der Cybersicherheit auf dem neuesten Stand zur Anwendung gelangen,
 6. zur Förderung und Entwicklung der allgemeinen und beruflichen Bildung im Bereich der Cybersicherheit, von Kompetenzen, Sensibilisierungsmaßnahmen, Forschungs- und Entwicklungsinitiativen im Bereich der Cybersicherheit sowie der Anleitung zu guten Vorgehensweisen und von Kontrollen im Bereich der Cyberhygiene für Bürgerinnen und Bürger, Interessenträger und Einrichtungen,
 7. zur Unterstützung von Hochschul- und Forschungseinrichtungen bei der Entwicklung und Verbesserung des Einsatzes von Cybersicherheitsinstrumenten und sicherer Netzinfrastruktur,
 8. mit einschlägigen Verfahren und geeigneten Instrumenten für den Informationsaustausch, um den freiwilligen Austausch von Cybersicherheitsinformationen zwischen Einrichtungen im Einklang mit dem Recht der Europäischen Union zu unterstützen,
 9. zur Stärkung des Grundniveaus für Cyberresilienz und Cyberhygiene kleiner und mittlerer Unternehmen (KMU) durch Bereitstellung leicht zugänglicher Orientierungshilfen und Unterstützung für ihre spezifischen Bedürfnisse und
 10. zur Förderung eines aktiven Cyberschutzes.
- (5) Die Cybersicherheitsbehörde übermittelt der Europäischen Kommission sowie der Bundesminister für Inneres dem Nationalrat die ÖSCS innerhalb von drei Monaten nach ihrem Erlass. Davon sind jedoch jene Bereiche auszunehmen, deren Verbreitung die nationale Sicherheit gefährden könnte.
- (6) Die Bundesregierung bewertet die ÖSCS regelmäßig, mindestens aber alle fünf Jahre, auf der Grundlage wesentlicher Leistungsindikatoren und aktualisiert diese erforderlichenfalls.

Management von Cybersicherheitsvorfällen großen Ausmaßes

§ 16. (1) Die Cybersicherheitsbehörde hat die Aufgaben für das Management von Cybersicherheitsvorfällen großen Ausmaßes wahrzunehmen.

(2) Zu diesem Zweck hat die Cybersicherheitsbehörde Kapazitäten, Mittel und Verfahren, die im Fall eines Cybersicherheitsvorfalls großen Ausmaßes eingesetzt werden können, zu ermitteln. Dabei hat sie das Lagebild, welches im Rahmen der Koordinierungsstrukturen (§§ 13 und 14) erstellt und aktualisiert wird, zu berücksichtigen.

(3) Die Cybersicherheitsbehörde hat einen nationalen Plan für die Reaktion auf Cybersicherheitsvorfälle großen Ausmaßes zu verabschieden und diesen der CSS zur Berücksichtigung in der zu erstellenden nationalen Cybersicherheitsstrategie gemäß § 15 Abs. 3 Z 1 zu übermitteln. In diesem Plan wird insbesondere Folgendes beschrieben:

1. die Ziele der nationalen Vorsorgemaßnahmen und -tätigkeiten;
2. die Aufgaben und Zuständigkeiten der Behörden im Rahmen des Managements von Cybersicherheitsvorfällen großen Ausmaßes;
3. die Verfahren für das Management von Cybersicherheitsvorfällen großen Ausmaßes, einschließlich deren Integration in den nationalen Rahmen für das allgemeine Krisenmanagement und der Kanäle für den Informationsaustausch;
4. die nationalen Vorsorgemaßnahmen, einschließlich Übungen und Ausbildungsmaßnahmen;
5. die einschlägigen öffentlichen und privaten Interessenträger und die betroffene Infrastruktur;
6. die zwischen den einschlägigen nationalen Behörden und Stellen vereinbarten nationalen Verfahren und Regelungen, die gewährleisten sollen, dass sich die Republik Österreich wirksam am koordinierten Management von Cybersicherheitsvorfällen großen Ausmaßes auf Ebene der Europäischen Union beteiligen und dieses unterstützen kann.

(4) Die Cybersicherheitsbehörde übermittelt die einschlägigen Informationen über den gemäß Abs. 3 erstellten Plan für die Reaktion auf Cybersicherheitsvorfälle großen Ausmaßes sowohl an die Europäische Kommission als auch an das EU-CyCLONe. Davon sind jedoch jene Bereiche auszunehmen, deren Verbreitung die nationale Sicherheit gefährden könnte.

5. Abschnitt

IKT-Lösungen

Betrieb von IKT-Lösungen

§ 17. (1) Die Cybersicherheitsbehörde hat für die Erfüllung ihrer behördlichen Aufgaben nach diesem Bundesgesetz IKT-Lösungen zu betreiben.

(2) Die Cybersicherheitsbehörde ist zur Erfüllung der Aufgabe gemäß § 4 Abs. 1 Z 4 ermächtigt, IKT-Lösungen zu betreiben, die Risiken, Cyberbedrohungen oder Cybersicherheitsvorfälle von Netz- und Informationssystemen frühzeitig erkennen. Wesentliche und wichtige Einrichtungen können an den von der Cybersicherheitsbehörde betriebenen IKT-Lösungen teilnehmen und festlegen, welche Daten an die Cybersicherheitsbehörde übermittelt werden. Für die Teilnahme an den IKT-Lösungen gebührt dem Bund als Ersatz ein Pauschalbetrag, der nach Maßgabe der durchschnittlichen Kosten mit Verordnung der Cybersicherheitsbehörde festgelegt wird.

(3) Die Cybersicherheitsbehörde ist zur Erfüllung der Aufgabe gemäß § 4 Abs. 1 Z 4 ermächtigt, IKT-Lösungen zu betreiben oder nach Einwilligung der betroffenen Einrichtung zu nutzen, um die Muster von Angriffen auf Netz- und Informationssysteme zu erkennen. Ebenso ist das GovCERT zum Betrieb solcher IKT-Lösungen zwecks Wahrnehmung der Aufgaben gemäß § 8 Abs. 1 Z 1, 2 und 4 ermächtigt und darf die daraus gewonnenen personenbezogenen technischen Daten als datenschutzrechtlicher Verantwortlicher gemäß Art. 4 Z 7 der Verordnung (EU) 2016/679 zum Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten, zum freien Datenverkehr und zur Aufhebung der Richtlinie 95/46/EG (Datenschutz-Grundverordnung), ABl. Nr. L 119 vom 04.05.2016 S. 1, in der Fassung der Berichtigung ABl. Nr. L 74 vom 04.03.2021 S. 35, (im Folgenden: DSGVO) und § 36 Abs. 2 Z 8 des Datenschutzgesetzes (DSG), BGBl. I Nr. 165/1999, verarbeiten.

Meldeanalysesystem

§ 18. (1) Für die Analyse von Meldungen über Risiken, Cyberbedrohungen und Cybersicherheitsvorfälle gemäß den §§ 34 und 37 sowie von Erkenntnissen, die gemäß § 17 gewonnen wurden, hat die Cybersicherheitsbehörde IKT-Lösungen zu betreiben und dem Bundesminister für Inneres, dem Bundeskanzler und dem Bundesminister für Landesverteidigung bereitzustellen, um die

Bewertung von Risiken, Cyberbedrohungen und Cybersicherheitsvorfällen sowie die Erstellung eines Lagebilds mittels strategischer oder operativer Analyse zu unterstützen.

(2) Für die IKT-Lösungen und IT-Verfahren des Abs. 1 sind die Cybersicherheitsbehörde, der Bundesminister für Inneres, der Bundeskanzler und der Bundesminister für Landesverteidigung gemeinsam datenschutzrechtliche Verantwortliche gemäß Art. 4 Z 7 in Verbindung mit Art. 26 DSGVO sowie § 47 DSGVO.

(3) Macht eine betroffene Person ihre Rechte gemäß den Bestimmungen des Kapitels III DSGVO oder den §§ 42 bis 45 DSGVO geltend, so haben die gemeinsam datenschutzrechtlich Verantwortlichen dies einander unverzüglich mitzuteilen. Jeder der gemeinsam datenschutzrechtlich Verantwortlichen hat bezüglich der von ihm erhobenen und verarbeiteten Daten die Pflichten in Zusammenhang mit den Rechten betroffener Personen selbstständig wahrzunehmen.

IKDOK-Plattform

§ 19. (1) Die Cybersicherheitsbehörde kann für die Organisation des IKDOK und zur Wahrnehmung der Aufgaben gemäß § 13 Abs. 1 eine IKT-Lösung betreiben. Im Falle des Betriebs einer solchen ist diese dem Bundesminister für Inneres, dem Bundeskanzler, dem Bundesminister für Landesverteidigung und dem Bundesminister für europäische und internationale Angelegenheiten bereitzustellen.

(2) Für die IKT-Lösung gemäß Abs. 1 sind die Cybersicherheitsbehörde, der Bundesminister für Inneres, der Bundeskanzler, der Bundesminister für Landesverteidigung und der Bundesminister für europäische und internationale Angelegenheiten gemeinsam datenschutzrechtlich Verantwortliche gemäß Art. 4 Z 7 in Verbindung mit Art. 26 DSGVO sowie § 47 DSGVO.

(3) Macht eine betroffene Person ihre Rechte gemäß den Bestimmungen des Kapitels III DSGVO oder den §§ 42 bis 45 DSGVO geltend, so haben die gemeinsam datenschutzrechtlich Verantwortlichen dies einander unverzüglich mitzuteilen. Jeder der gemeinsam datenschutzrechtlich Verantwortlichen hat bezüglich der von ihm erhobenen und verarbeiteten Daten die Pflichten in Zusammenhang mit den Rechten betroffener Personen selbstständig wahrzunehmen.

6. Abschnitt

Zusammenarbeit auf nationaler, Unions- und internationaler Ebene

Zusammenarbeit auf nationaler Ebene

§ 20. (1) Die Cybersicherheitsbehörde und die CSIRTs arbeiten bei der Erfüllung ihrer Aufgaben nach diesem Bundesgesetz zusammen.

(2) Die Cybersicherheitsbehörde hat für die Erfüllung ihrer gesetzlichen Aufgaben und Pflichten nach diesem Bundesgesetz insbesondere mit

1. der Kriminalpolizei, den Staatsanwaltschaften und Gerichten,
2. den Behörden, die das Luftfahrtsicherheitsgesetz 2011 (LSG 2011), BGBl. I Nr. 111/2010 vollziehen, sowie den Behörden, die als zuständige nationale Aufsichtsbehörde oder zuständige nationale Behörde gemäß der Verordnung (EU) 2018/1139 zur Festlegung gemeinsamer Vorschriften für die Zivilluftfahrt und zur Errichtung einer Agentur der Europäischen Union für Flugsicherheit sowie zur Änderung der Verordnungen (EG) Nr. 2111/2005, (EG) Nr. 1008/2008, (EU) Nr. 996/2010, (EU) Nr. 376/2014 und der Richtlinien 2014/30/EU und 2014/53/EU des Europäischen Parlaments und des Rates, und zur Aufhebung der Verordnungen (EG) Nr. 552/2004 und (EG) Nr. 216/2008 des Europäischen Parlaments und des Rates und der Verordnung (EWG) Nr. 3922/91 des Rates, ABl. Nr. L 212 vom 22.08.2018 S. 1, sowie deren delegierte Rechtsakte und Durchführungsrechtsakte benannt sind,
3. den Behörden, welche innerstaatlich die Einhaltung der Verordnung (EU) 2022/2554 sicherstellen,
4. der Aufsichtsstelle gemäß § 12 SVG,
5. der nationalen Regulierungsbehörde gemäß § 194 TKG 2021 sowie
6. der KommAustria gemäß § 199 TKG 2021

zusammenzuarbeiten und kann in diesem Zusammenhang Informationen über relevante Umstände, die auch personenbezogene Daten beinhalten können, austauschen, soweit diese im Aufgabenbereich der jeweiligen Behörden liegen und dies der Erhöhung der Cybersicherheit dient.

(3) Kriminalpolizei, Staatsanwaltschaften und Gerichte sind ermächtigt, der Cybersicherheitsbehörde nach Maßgabe des § 76 Abs. 4 der Strafprozeßordnung 1975 (StPO), BGBl. Nr. 631/1975, ermittelte

personenbezogene Daten zu übermitteln, soweit eine Weiterverarbeitung dieser Daten durch die Cybersicherheitsbehörde für die Erfüllung ihrer gesetzlichen Aufgaben und Pflichten nach diesem Bundesgesetz erforderlich ist.

(4) Die Cybersicherheitsbehörde arbeitet mit der gemäß der Richtlinie (EU) 2022/2557 zuständigen Behörde hinsichtlich der Identifizierung kritischer Einrichtungen gemäß der Richtlinie (EU) 2022/2557, zu Risiken, Cyberbedrohungen und Cybersicherheitsvorfällen sowie zu nicht cyberbezogenen Risiken, Bedrohungen und Sicherheitsvorfällen zusammen und tauscht mit dieser Informationen zu den als Reaktion ergriffenen Maßnahmen und darüberhinausgehende Informationen aus.

(5) Die Cybersicherheitsbehörde hat vor der Durchführung von Aufsichts- und Durchsetzungsmaßnahmen gegenüber Einrichtungen, die gemäß § 24 Abs. 1 Z 1 lit. f als wesentliche Einrichtungen gelten, jene Behörde, die in Umsetzung von Art. 9 der Richtlinie (EU) 2022/2557 als zuständige Behörde benannt oder eingerichtet wurde, zu unterrichten.

(6) Die Cybersicherheitsbehörde hat auf Ersuchen jener Behörde, die in Umsetzung des Art. 9 der Richtlinie (EU) 2022/2557 als zuständige Behörde benannt oder eingerichtet wurde, Aufsichts- und Durchsetzungsmaßnahmen gegenüber Einrichtungen auszuüben, die gemäß der Richtlinie (EU) 2022/2557 als kritische Einrichtungen eingestuft wurden.

(7) Die Cybersicherheitsbehörde hat vor der Durchführung von Aufsichts- und Durchsetzungsmaßnahmen gegenüber wesentlichen und wichtigen Einrichtungen, die als IKT-Drittdienstleister gemäß Art. 31 der Verordnung (EU) 2022/2554 benannt wurden, das gemäß Art. 32 Abs. 1 der Verordnung (EU) 2022/2554 eingerichtete Überwachungsforum zu unterrichten.

(8) Ein Informationsaustausch mit der Aufsichtsstelle gemäß Abs. 2 Z 4 hat jedenfalls in Angelegenheiten zu erfolgen, die Risiken, Cyberbedrohungen und Cybersicherheitsvorfälle eines Vertrauensdiensteanbieters oder Schwachstellen einer qualifizierten elektronischen Signaturerstellungseinheit, einer qualifizierten elektronischen Siegelerstellungseinheit oder der vertrauenswürdigen Systeme eines Vertrauensdiensteanbieters betreffen.

(9) Die Cybersicherheitsbehörde hat vor der Durchführung von Aufsichts- und Durchsetzungsmaßnahmen gegenüber Betreibern gemäß § 4 Z 25 TKG 2021 und Anbietern gemäß § 4 Z 36 TKG 2021 die nationale Regulierungsbehörde gemäß § 194 TKG 2021 und die KommAustria gemäß § 199 TKG 2021 zu unterrichten.

Zusammenarbeit mit der Datenschutzbehörde

§ 21. (1) Die Cybersicherheitsbehörde und die Datenschutzbehörde, unbeschadet ihrer Zuständigkeiten und Aufgaben nach der DSGVO und dem DSG, haben bei der Bearbeitung und der Anordnung von Abwehr- und Abhilfemaßnahmen von Cybersicherheitsvorfällen, die zur Verletzung des Schutzes personenbezogener Daten gemäß Art. 4 Z 12 DSGVO und § 36 Abs. 2 Z 1 DSG führen, zusammenzuarbeiten und tauschen die hierzu erforderlichen Informationen aus. Die Cybersicherheitsbehörde gewährt der Datenschutzbehörde zu diesem Zweck Zugang zum Register gemäß § 29.

(2) Besteht Grund zur Annahme, dass ein Verstoß einer wesentlichen oder wichtigen Einrichtung gegen die in den §§ 32 und 34 festgelegten Verpflichtungen eine Verletzung des Schutzes personenbezogener Daten zur Folge hat, die gemäß Art. 33 DSGVO zu melden ist, hat die Cybersicherheitsbehörde unverzüglich, möglichst innerhalb von 72 Stunden, die Datenschutzbehörde zu unterrichten. Betrifft die Verletzung des Schutzes personenbezogener Daten Betroffene in einem anderen Mitgliedstaat der Europäischen Union, hat die Cybersicherheitsbehörde ebenfalls die Datenschutzbehörde zu unterrichten.

(3) Verhängt die Datenschutzbehörde gegen eine wesentliche oder wichtige Einrichtung aufgrund eines Cybersicherheitsvorfalles, der zur Verletzung des Schutzes personenbezogener Daten gemäß Art. 4 Z 12 DSGVO geführt hat, gemäß Art. 58 Abs. 2 lit. i DSGVO eine Geldbuße, hat sie über diesen Umstand die Cybersicherheitsbehörde zu informieren und ihr eine Ausfertigung des Straferkenntnisses zu übersenden. Ebenso hat sie die Cybersicherheitsbehörde über den Umstand der Einstellung eines Verfahrens gemäß diesem Absatz zu informieren. Für den Fall, dass die Verwaltungsübertretung bereits von der zuständigen Bezirksverwaltungsbehörde verfolgt wird, hat die Cybersicherheitsbehörde die Bezirksverwaltungsbehörde über diesen Umstand zu informieren.

Internationale Zusammenarbeit

§ 22. (1) Erbringt eine Einrichtung ihre Dienste in mehr als einem Mitgliedstaat der Europäischen Union oder erbringt sie ihre Dienste in einem oder mehreren Mitgliedstaaten und befinden sich ihre Netz- und Informationssysteme in einem oder mehreren anderen Mitgliedstaaten, arbeitet die

Cybersicherheitsbehörde mit den zuständigen Behörden der betreffenden Mitgliedstaaten zusammen und unterstützt diese.

(2) Die Zusammenarbeit gemäß Abs. 1 umfasst dabei mindestens Folgendes:

1. über die zentralen Anlaufstellen unterrichtet die Cybersicherheitsbehörde die zuständigen Behörden in den anderen betreffenden Mitgliedstaaten über die Aufsichts- und Durchsetzungsmaßnahmen und konsultiert sie zu diesen;
2. die Cybersicherheitsbehörde kann eine andere zuständige Behörde ersuchen, Aufsichts- oder Durchsetzungsmaßnahmen zu ergreifen;
3. auf begründetes Ersuchen einer anderen zuständigen Behörde leistet die Cybersicherheitsbehörde dem Rechtshilfeersuchen der ersuchenden Behörde in einem den zur Verfügung stehenden Ressourcen angemessenen Umfang Folge, damit die Aufsichts- oder Durchsetzungsmaßnahmen wirksam, effizient und kohärent durchgeführt werden können. Das Rechtshilfeersuchen kann die Erteilung von Auskünften und die Durchführung von Aufsichtsmaßnahmen, einschließlich der Durchführung von Vor-Ort-Kontrollen, externen Aufsichtsmaßnahmen und gezielten Überprüfungen, umfassen.

(3) Die Cybersicherheitsbehörde darf ein Rechtshilfeersuchen nur ablehnen, wenn sie für die erbetene Rechtshilfe nicht zuständig ist, die ersuchte Rechtshilfe in keinem angemessenen Verhältnis zu ihren Aufsichtsaufgaben steht oder das Ersuchen Informationen betrifft oder Tätigkeiten umfasst, deren Offenlegung oder Ausführung wesentlichen Interessen im Bereich der nationalen Sicherheit, der öffentlichen Sicherheit oder der Landesverteidigung zuwiderlaufen würde. Bevor die Cybersicherheitsbehörde einen solchen Antrag ablehnt, konsultiert sie die anderen betreffenden zuständigen Behörden sowie – auf Ersuchen eines der betreffenden Mitgliedstaaten – die Kommission und die ENISA.

(4) Die Cybersicherheitsbehörde kann, wenn dies gemäß Abs. 3 möglich und im gegenseitigen Einvernehmen geschieht, gemeinsame Aufsichtsmaßnahmen durchführen.

Peer Reviews

§ 23. (1) Die Cybersicherheitsbehörde kann an den in Art. 19 NIS-2-Richtlinie angeführten Peer Reviews teilnehmen.

(2) Die Cybersicherheitsbehörde stellt den beigezogenen Sachverständigen für Cybersicherheit die für die Bewertung erforderlichen Informationen zur Verfügung, vorbehaltlich der nationalen Rechtsvorschriften über den Schutz vertraulicher oder als Verschlusssache eingestufte Informationen und der Wahrung grundlegender Funktionen des Staates wie der nationalen Sicherheit. Sämtliche durch die Peer Reviews erlangten Informationen dürfen nur zu diesem Zweck verwendet werden. Die an dem Peer Review beteiligten Sachverständigen für Cybersicherheit geben keine sensiblen oder vertraulichen Informationen, die im Laufe des Peer Reviews erlangt wurden, an Dritte weiter.

(3) Die Cybersicherheitsbehörde kann, wenn sie Gegenstand des Peer Reviews ist, unter Mitteilung stichhaltiger Gründe Einwände gegen die Benennung bestimmter Sachverständiger für Cybersicherheit erheben.

(4) Die an Peer Reviews beteiligten Sachverständigen für Cybersicherheit haben Berichte über die Ergebnisse und Schlussfolgerungen der Peer Reviews zu erstellen. Zu den sie betreffenden Berichtsentwürfen kann die Cybersicherheitsbehörde Stellung nehmen; diese Stellungnahmen werden den Berichten beigelegt.

3. Hauptstück

Wesentliche und wichtige Einrichtungen und Einrichtungen, die Domänennamen-Registrierungsdienste erbringen

1. Abschnitt

Wesentliche und wichtige Einrichtungen

Wesentliche und wichtige Einrichtungen

§ 24. (1) Als wesentliche Einrichtungen gelten

1. unabhängig von der Unternehmensgröße
 - a) qualifizierte Vertrauensdiensteanbieter,
 - b) Namenregister der Domäne oberster Stufe (TLD Namenregister),

- c) DNS-Diensteanbieter,
 - d) Einrichtungen im Sektor der öffentlichen Verwaltung auf Bundesebene gemäß Abs. 4,
 - e) Einrichtungen, die von der Cybersicherheitsbehörde als wesentliche Einrichtung eingestuft wurden (§ 26 Abs. 1 und 2) sowie
 - f) Einrichtungen, die als kritische Einrichtungen gemäß der Richtlinie (EU) 2022/2557 ermittelt wurden;
2. Einrichtungen, die ein mittleres Unternehmen gemäß § 25 Abs. 3 betreiben und Anbieter öffentlicher elektronischer Kommunikationsnetze oder Anbieter öffentlich zugänglicher elektronischer Kommunikationsdienste sind;
3. Einrichtungen der in **Anlage 1** dieses Gesetzes genannten Art, die ein großes Unternehmen gemäß § 25 Abs. 2 betreiben.
- (2) Als wichtige Einrichtung gelten
- 1. Einrichtungen der in den **Anlagen 1 und 2** dieses Gesetzes genannten Art, die ein großes oder mittleres Unternehmen betreiben sowie
 - 2. Einrichtungen im Sektor der öffentlichen Verwaltung auf Landesebene gemäß Abs. 5 und
 - 3. unabhängig von ihrer Größe
 - a. Anbieter von öffentlichen elektronischen Kommunikationsnetzen oder von öffentlich zugänglichen Kommunikationsdiensten,
 - b. Vertrauensdiensteanbieter und
 - c. Einrichtungen, die von der Cybersicherheitsbehörde als wichtige Einrichtung eingestuft wurden (§ 26 Abs. 1),
- und diese Einrichtung nicht bereits eine wesentliche Einrichtung gemäß Abs. 1 ist.
- (3) Einrichtungen im Sektor der öffentlichen Verwaltung sind Einrichtungen, die
- 1. zum Zweck eingerichtet wurden, im öffentlichen Interesse liegende Aufgaben nicht gewerblicher Art zu erfüllen,
 - 2. der Aufsicht des Bundes oder eines Landes unterstehen oder an die Weisungen eines obersten Organs gebunden sind oder ein Leitungs- oder Aufsichtsorgan haben, das mehrheitlich aus Mitgliedern besteht, die von Bundes- oder Landesbehörden oder von anderen auf Bundes- oder Landesebene eingerichteten Körperschaften des öffentlichen Rechts eingesetzt worden sind, oder an denen der Bund oder ein Land mit mindestens 50 vH des Stamm-, Grund- oder Eigenkapitals beteiligt ist oder die Mitglieder der Bundesregierung sind und
 - 3. ermächtigt sind, im Rahmen ihrer gesetzlich übertragenen Aufgaben Bescheide zu erlassen, die Rechte Einzelner im grenzüberschreitenden Personen-, Waren, Dienstleistungs- oder Kapitalverkehr berühren,
- mit Ausnahme der Gemeinden sowie Gemeindeverbände.
- (4) Einrichtungen im Sektor der öffentlichen Verwaltung auf Bundesebene sind Einrichtungen gemäß Abs. 3, die zudem zur Besorgung von Angelegenheiten der Bundesverwaltung berufen sind und entweder als Bundesbehörden eingerichtet wurden oder Rechtspersönlichkeit besitzen. Die übrigen Mitglieder der Bundesregierung haben der Cybersicherheitsbehörde erstmalig innerhalb von drei Monaten ab Inkrafttreten dieses Bundesgesetzes und im Anschluss anlassbezogen, längstens jedoch alle drei Jahre, eine Liste der in ihren Wirkungsbereich fallenden Einrichtungen zu übermitteln.
- (5) Einrichtungen im Sektor der öffentlichen Verwaltung auf Landesebene sind die Ämter der Landesregierungen und die Bezirkshauptmannschaften sowie Einrichtungen gemäß Abs. 3, die zudem zur Besorgung von Angelegenheiten der Landesverwaltung berufen sind und Rechtspersönlichkeit besitzen.
- (6) Einrichtungen im Sektor der öffentlichen Verwaltung, deren Wirkungsbereiche überwiegend die nationale Sicherheit einschließlich der militärischen Landesverteidigung, die öffentliche Sicherheit oder die Strafverfolgung umfassen, sowie Einrichtungen des Universitäts-, Hochschul- und Schulwesens, Einrichtungen der Gerichtsbarkeit einschließlich der kollegialen und monokratischen Justizverwaltung, Einrichtungen der Gesetzgebung einschließlich der Parlamentsdirektion, sowie die Österreichische Nationalbank gelten nicht als wesentliche oder wichtige Einrichtungen. Für Vertrauensdiensteanbieter kommt dieser Absatz nicht zur Anwendung.
- (7) Gegenüber Einrichtungen, die in den Anwendungsbereich der Verordnung (EU) 2022/2554 fallen, gehen die einschlägigen Bestimmungen dieser Verordnung und nationaler Durchführungsbestimmungen vor. Dies gilt auch für jene Einrichtungen, die gemäß Art. 2 Abs. 4

Verordnung (EU) 2022/2554 im Rahmen der innerstaatlichen Durchführung von deren Anwendungsbereich ausgenommen wurden.

(8) IKT-Drittdienstleister gemäß Art. 3 Z 23 der Verordnung (EU) 2022/2554 unterliegen auch den Bestimmungen dieses Bundesgesetzes.

(9) Unbeschadet des Abs. 6 erster Satz haben der Bundesminister für Inneres, die Bundesministerin für Justiz und der Bundesminister für Landesverteidigung im jeweiligen Wirkungsbereich sowie der Präsident des Nationalrats im Bereich der diesem zustehenden Verwaltungsangelegenheiten die notwendigen strukturellen Voraussetzungen zur Sicherstellung eines hohen Cybersicherheitsniveaus zu schaffen.

Ermittlung der Unternehmensgröße

§ 25. (1) Die Einstufung einer Einrichtung als „mittleres Unternehmen“ oder als „großes Unternehmen“ richtet sich nach der Anzahl der Mitarbeiter, dem Jahresumsatz und der Jahresbilanzsumme. Diese Einstufung erfolgt unter Anwendung der Art. 1 bis 6 des Anhangs der Empfehlung 2003/361/EG der Kommission vom 06. Mai 2003 betreffend die Definition der Kleinstunternehmen sowie der kleinen und mittleren Unternehmen, ABl. Nr. L 124 vom 20.5.2003 S. 36, mit Ausnahme des Art. 3 Abs. 4 des Anhangs dieser Empfehlung.

(2) Eine Einrichtung gilt als „großes Unternehmen“, wenn sie zumindest 250 Mitarbeiter beschäftigt oder wenn sie einen Jahresumsatz von über 50 Millionen Euro erzielt und sich die Jahresbilanzsumme auf über 43 Millionen Euro beläuft.

(3) Eine Einrichtung gilt als „mittleres Unternehmen“, wenn sie zumindest 50 Mitarbeiter beschäftigt, oder wenn sie einen Jahresumsatz von über zehn Millionen Euro erzielt und sich die Jahresbilanzsumme auf über zehn Millionen Euro beläuft, sofern sie nicht bereits als großes Unternehmen gilt.

(4) Bei der Bestimmung der Anzahl der Mitarbeiter, des Jahresumsatzes und der Jahresbilanzsumme für die Zwecke der Abs. 1 bis 3 sind die Daten von Partner- oder verbundenen Unternehmen gemäß Art. 6 Abs. 2 des Anhangs der Empfehlung 2003/361/EG nicht hinzuzurechnen, wenn die Einrichtung in Bezug auf die Netz- und Informationssysteme, die sie bei der Erbringung ihrer Dienste nutzt, sowie unter Berücksichtigung der Beschaffenheit, des Betriebs und der Sicherheit ihrer Netz- und Informationssysteme organisatorisch, technisch und operativ unabhängig von ihren Partner- oder verbundenen Unternehmen ist.

Größenunabhängige Einstufung als wesentliche oder wichtige Einrichtung

§ 26. (1) Die Cybersicherheitsbehörde hat eine Einrichtung der in den **Anlagen 1 oder 2** genannten Art, die aufgrund ihrer Unternehmensgröße nicht als wesentlich oder als wichtig gilt, aus den in Abs. 3 genannten Gründen mit Bescheid als wesentliche Einrichtung oder als wichtige Einrichtung einzustufen.

(2) Die Cybersicherheitsbehörde hat eine wichtige Einrichtung mit Bescheid als wesentliche Einrichtung einzustufen, sofern dies aus den in Abs. 3 genannten Gründen geboten ist.

(3) Aus folgenden Gründen hat eine Einstufung einer Einrichtung als wesentliche Einrichtung oder als wichtige Einrichtung zu erfolgen:

1. es handelt sich bei der Einrichtung um den einzigen Anbieter eines Dienstes in Österreich, der für die Aufrechterhaltung kritischer gesellschaftlicher oder wirtschaftlicher Tätigkeiten unerlässlich ist;
2. eine Störung des von der Einrichtung erbrachten Dienstes könnte sich wesentlich auf die öffentliche Ordnung, die öffentliche Sicherheit oder die öffentliche Gesundheit auswirken;
3. eine Störung des von der Einrichtung erbrachten Dienstes könnte zu einem wesentlichen Systemrisiko führen, insbesondere in Sektoren, in denen eine solche Störung grenzübergreifende Auswirkungen haben könnte;
4. die Einrichtung ist aufgrund der besonderen Bedeutung, die sie auf nationaler oder regionaler Ebene für den betreffenden Sektor oder die betreffende Art des Dienstes oder für andere voneinander abhängige Sektoren hat, kritisch.

Ausnahmen von Verpflichtungen für wesentliche oder wichtige Einrichtungen aufgrund sektorspezifischer Rechtsakte der Europäischen Union

§ 27. (1) Die Anforderungen gemäß den §§ 32 und 34 sind insoweit nicht anwendbar,

1. als wesentliche oder wichtige Einrichtungen aufgrund sektorspezifischer unionsrechtlicher Bestimmungen zur Ergreifung von Risikomanagementmaßnahmen oder zur Meldung erheblicher Cybersicherheitsvorfälle verpflichtet sind und

2. die jeweiligen Bestimmungen dieser sektorspezifischen Rechtsakte ein zumindest gleichwertiges Cybersicherheitsniveau gewährleisten.

Die Cybersicherheitsbehörde hat über die Bestimmungen gemäß Z 1 und das Ausmaß der Gleichwertigkeit gemäß Z 2 auf der Webseite der Cybersicherheitsbehörde zu informieren.

(2) Die Verpflichtungen der sektorspezifischen unionsrechtlichen Bestimmungen gelten als gleichwertig, sofern

1. Inhalt, Umfang, Zweck und potenzielle Auswirkungen der aufgrund dieser Bestimmungen zu ergreifenden Maßnahmen auf das Cybersicherheitsniveau den Anforderungen gemäß § 32 entsprechen;
2. diese einen unmittelbaren Zugang zu den Meldungen von Sicherheitsvorfällen durch die CSIRTs oder die Cybersicherheitsbehörde vorsehen sowie Umfang und Auswirkungen der vorgesehenen Berichtspflichten jenen gemäß § 34 entsprechen.

Territorialität

§ 28. (1) Wesentliche und wichtige Einrichtungen sowie Einrichtungen, die Domännennamen-Registrierungsdienste erbringen, unterliegen den Bestimmungen dieses Hauptstücks, wenn sie in Österreich niedergelassen sind.

(2) Abweichend von Abs. 1 gelten die Bestimmungen dieses Hauptstücks für folgende Einrichtungen nur unter den hier angeführten Bedingungen:

1. für Anbieter öffentlicher Kommunikationsnetze oder Anbieter öffentlich zugänglicher elektronischer Kommunikationsdienste, sofern sie ihre Dienste in Österreich erbringen;
2. für DNS-Diensteanbieter, TLD-Namenregister, Einrichtungen, die Domännennamen-Registrierungsdienste erbringen, Anbieter von Cloud-Computing-Diensten, Anbieter von Rechenzentrumsdiensten, Betreiber von Inhaltszustellnetzen, Anbieter von verwalteten Diensten, Anbieter von verwalteten Sicherheitsdiensten sowie Anbieter von Online-Marktplätzen, Online-Suchmaschinen oder Plattformen für Dienste sozialer Netzwerke, sofern sie
 - a. ihre Hauptniederlassung in Österreich haben oder
 - b. sie weder in Österreich, noch in einem anderen Mitgliedstaat der Europäischen Union einen Vertreter gemäß Abs. 4 bestellt haben;
3. für Einrichtungen im Sektor der öffentlichen Verwaltung gemäß § 24 Abs. 3, unabhängig von ihrem Niederlassungsort innerhalb der Europäischen Union.

(3) Als Hauptniederlassung gemäß Abs. 2 Z 2 wird jeweils die Niederlassung in demjenigen Mitgliedstaat der Europäischen Union betrachtet, in dem die Entscheidungen im Zusammenhang mit den Risikomanagementmaßnahmen vorwiegend getroffen werden. Kann dies nicht eindeutig bestimmt werden oder werden solche Entscheidungen nicht in der Europäischen Union getroffen, so gilt als Hauptniederlassung der Mitgliedstaat, in dem die Risikomanagementmaßnahmen gesetzt werden. Kann dies nicht ermittelt werden, so gilt die Hauptniederlassung als in jenem Mitgliedstaat gelegen, in dem die betreffende Einrichtung die Niederlassung mit der höchsten Beschäftigtenzahl in der Europäischen Union hat.

(4) Hat eine wesentliche oder wichtige Einrichtung gemäß Abs. 2 Z 2 keine Niederlassung in der Europäischen Union, bietet aber Dienste innerhalb Österreichs an, hat sie, wenn sie keinen zur Empfangnahme von Dokumenten befugten Vertreter mit Hauptwohnsitz im Inland hat, der Cybersicherheitsbehörde einen Zustellungsbevollmächtigten gemäß § 9 des Zustellgesetzes (ZustG), BGBl. Nr. 200/1982, namhaft zu machen, sofern sie einen solchen Vertreter nicht bereits in einem anderen Mitgliedstaat der Europäischen Union benannt hat. Wurde kein Zustellungsbevollmächtigter benannt, gelten für die wesentliche oder wichtige Einrichtung die Bestimmungen nach diesem Hauptstück und die Cybersicherheitsbehörde kann nach dem 4. Abschnitt dieses Hauptstücks vorgehen.

(5) Die Benennung eines Vertreters durch eine in Abs. 2 Z 2 genannte Einrichtung lässt rechtliche Schritte, die gegen die Einrichtung selbst eingeleitet werden könnten, unberührt.

(6) Erhält die Cybersicherheitsbehörde von einem anderen Mitgliedstaat der Europäischen Union ein Rechtshilfeersuchen zu einer in den Abs. 1 und 2 genannten Einrichtung, die in Österreich Dienste anbietet oder ein Netz- und Informationssystem betreibt, kann sie innerhalb der Grenzen des Rechtshilfeersuchens geeignete Aufsichts- und Durchsetzungsmaßnahmen nach diesem Bundesgesetz in Bezug auf die betreffende Einrichtung ergreifen. § 22 gilt sinngemäß.

2. Abschnitt

Pflichten

Register der Einrichtungen

§ 29. (1) Die Cybersicherheitsbehörde hat ein Register der wesentlichen und wichtigen Einrichtungen einschließlich der Einrichtungen, die Domänennamen-Registrierungsdienste erbringen, zu führen, dieses in regelmäßigen Abständen, längstens jedoch alle zwei Jahre zu überprüfen und gegebenenfalls anzupassen.

(2) Die in Abs. 1 genannten Einrichtungen haben sich bei der Cybersicherheitsbehörde zu registrieren und dieser im elektronischen Weg folgende Angaben über einen sicheren Kommunikationskanal strukturiert zu übermitteln:

1. den Namen der Einrichtung;
2. die Anschrift und aktuelle Kontaktdaten sowie gegebenenfalls den gemäß § 28 Abs. 4 benannten Vertreter;
3. den Sektor oder die Sektoren, den Teilsektor oder die Teilsektoren und die Art oder Arten der Einrichtung gemäß **Anlage 1 oder 2**;
4. die Mitgliedstaaten der Europäischen Union, in denen sie Dienste erbringt;
5. gegebenenfalls die IP-Adressbereiche der Einrichtung;
6. die Anschrift der Hauptniederlassung der Einrichtung und ihrer sonstigen Niederlassungen in der Europäischen Union oder, falls sie nicht in der Europäischen Union niedergelassen ist, die Anschrift ihres gemäß § 28 Abs. 4 benannten Vertreters;
7. Informationen zu den in § 25 angeführten Schwellenwerten und darüber, ob es sich um eine wesentliche oder wichtige Einrichtung handelt.

(3) Die Registrierung gemäß Abs. 2 hat innerhalb von drei Monaten ab Inkrafttreten dieses Bundesgesetzes zu erfolgen. Einrichtungen, die erst nach diesem Zeitpunkt als wesentliche oder wichtige Einrichtungen gelten oder erst nach diesem Zeitpunkt Domänennamen-Registrierungsdienste erbringen, haben sich ehestmöglich, in jedem Fall aber innerhalb von drei Monaten ab Erfüllung der jeweiligen Voraussetzungen, zu registrieren.

(4) Die in Abs. 1 genannten Einrichtungen haben der Cybersicherheitsbehörde Änderungen der Angaben

1. gemäß Abs. 2 Z 1 bis 5 ehestmöglich, in jedem Fall aber innerhalb von zwei Wochen ab dem Tag der Änderung, und
2. gemäß Abs. 2 Z 6 und 7 ehestmöglich, in jedem Fall aber innerhalb von drei Monaten ab dem Tag der Änderung,

mitzuteilen.

(5) Die zentrale Anlaufstelle hat die in Abs. 2 Z 1 bis 4 und 6 genannten Angaben von DNS-Diensteanbietern, TLD-Namenregistern, Einrichtungen, die Domänennamen-Registrierungsdienste erbringen, Anbietern von Cloud-Computing-Diensten, Anbietern von Rechenzentrumsdiensten, Betreibern von Inhaltzustellnetzen, Anbietern von verwalteten Diensten, Anbietern von verwalteten Sicherheitsdiensten sowie Anbietern digitaler Dienste unverzüglich nach deren Erhalt an die ENISA weiterzuleiten.

(6) Die in Abs. 1 genannten Einrichtungen haben für den Empfang und Austausch von Cybersicherheitsinformationen mit der Cybersicherheitsbehörde eine Kontaktstelle bestehend aus zumindest einer Telefonnummer und E-Mailadresse der Kontaktdaten gemäß Abs. 2 Z 2 vorzusehen.

Datenbank der Domänennamen-Registrierungsdaten

§ 30. (1) Die TLD-Namenregister und die Einrichtungen, die Domänennamen-Registrierungsdienste erbringen, haben in einer eigenen Datenbank korrekte und vollständige Domänennamen-Registrierungsdaten zu sammeln.

(2) Eine Datenbank gemäß Abs. 1 hat die erforderlichen Angaben zu enthalten, anhand deren die Inhaber der Domänennamen und die Kontaktstellen, die die Domänennamen im Rahmen der TLD verwalten, identifiziert und kontaktiert werden können. Diese Angaben müssen die folgenden Informationen umfassen:

1. den Domänennamen;
2. das Datum der Registrierung;
3. den Namen des Domäneninhabers, seine E-Mail-Adresse und Telefonnummer;

4. die Kontakt-E-Mail-Adresse und die Telefonnummer der Anlaufstelle, die den Domännennamen verwaltet, falls diese sich von denen des Domäneninhabers unterscheiden.

(3) Die TLD-Namenregister und die Einrichtungen, die Domännennamen-Registrierungsdienste erbringen, haben Vorgaben und Verfahren, einschließlich Überprüfungsverfahren, zu etablieren, mit denen sichergestellt wird, dass Datenbanken gemäß Abs. 1 korrekte und vollständige Angaben enthalten, und diese Vorgaben und Verfahren öffentlich zugänglich zu machen.

(4) Die TLD-Namenregister und Einrichtungen, die Domännennamen-Registrierungsdienste erbringen, haben unverzüglich nach der Registrierung eines Domännennamens die nicht personenbezogenen Domännennamen-Registrierungsdaten öffentlich zugänglich zu machen.

(5) Die TLD-Namenregister und die Einrichtungen, die Domännennamen-Registrierungsdienste erbringen, haben auf rechtmäßige und hinreichend begründete Anträge von Einrichtungen Zugang zu den erfragten Domännennamen-Registrierungsdaten zu gewähren. Die TLD-Namenregister und Einrichtungen, die Domännennamen-Registrierungsdienste erbringen, haben die Vorgaben und Verfahren im Hinblick auf die Offenlegung solcher Daten öffentlich zugänglich zu machen und alle Anträge auf Zugang unverzüglich und in jedem Fall innerhalb von 72 Stunden nach Eingang eines Antrags zu beantworten.

(6) Die Einhaltung der in den Abs. 1 bis 5 festgelegten Verpflichtungen darf nicht zu einer doppelten Erhebung von Domännennamen-Registrierungsdaten führen, außer dies ist technisch nicht anders möglich. Zu diesem Zweck haben die TLD-Namenregister und die Einrichtungen, die Domännennamen-Registrierungsdienste erbringen, miteinander zusammenzuarbeiten.

Governance

§ 31. (1) Die Leitungsorgane wesentlicher und wichtiger Einrichtungen haben die Einhaltung der Risikomanagementmaßnahmen gemäß § 32 sicherzustellen und zu beaufsichtigen.

(2) Die Leitungsorgane wesentlicher und wichtiger Einrichtungen müssen an für diese spezifisch gestalteten Cybersicherheitsschulungen teilnehmen. Die Einrichtungen haben den Mitarbeitern regelmäßig entsprechende Schulungen anzubieten, damit diese ausreichende Kenntnisse und Fähigkeiten zur Erkennung und Bewertung von Risiken sowie Managementpraktiken im Bereich der Cybersicherheit und deren Auswirkungen auf die von der Einrichtung erbrachten Dienste erwerben können.

Risikomanagementmaßnahmen im Bereich der Cybersicherheit

§ 32. (1) Wesentliche und wichtige Einrichtungen haben geeignete und verhältnismäßige Risikomanagementmaßnahmen in technischer, operativer und organisatorischer Hinsicht umzusetzen, um die Risiken für die Sicherheit der Netz- und Informationssysteme, die sie für ihren Betrieb oder für die Erbringung ihrer Dienste nutzen, zu reduzieren und die Auswirkungen von Cybersicherheitsvorfällen auf die Nutzer ihrer Dienste und auf andere Dienste zu verhindern oder möglichst gering zu halten.

(2) Die Risikomanagementmaßnahmen haben zudem unter Berücksichtigung des Stands der Technik und gegebenenfalls der einschlägigen nationalen, europäischen und internationalen Normen sowie bewährter Verfahren und der Kosten der Umsetzung ein Cybersicherheitsniveau zu gewährleisten, das dem bestehenden Risiko angemessen ist.

(3) Bei der Beurteilung der Verhältnismäßigkeit der Risikomanagementmaßnahmen sind das Ausmaß der Risikoexposition der Einrichtung sowie ihrer Dienste, die Größe der Einrichtung und die Wahrscheinlichkeit des Eintretens von Cybersicherheitsvorfällen und deren Schwere, einschließlich ihrer gesellschaftlichen und wirtschaftlichen Auswirkungen, gebührend zu berücksichtigen.

(4) Diese Risikomanagementmaßnahmen haben auf einem gefahrenübergreifenden Ansatz zu beruhen, der auf den Schutz der Netz- und Informationssysteme samt deren physischen Komponenten vor Cybersicherheitsvorfällen abzielt, und zumindest folgende Inhalte zu umfassen:

- a) Konzepte in Bezug auf die Risikoanalyse und Sicherheit für Informationssysteme;
- b) Bewältigung von Cybersicherheitsvorfällen;
- c) Aufrechterhaltung des Betriebs, wie Backup-Management und Wiederherstellung nach einem Notfall, und Krisenmanagement;
- d) Sicherheit der Lieferkette einschließlich sicherheitsbezogener Aspekte der Beziehungen zwischen den einzelnen Einrichtungen und ihren unmittelbaren Anbietern oder Diensteanbietern, unter Berücksichtigung der spezifischen Schwachstellen der einzelnen unmittelbaren Anbieter und Diensteanbieter, der Gesamtqualität der Produkte und der Cybersicherheitspraxis ihrer Anbieter und Diensteanbieter, einschließlich der Sicherheit ihrer Entwicklungsprozesse, sowie der Ergebnisse der gemäß Art. 22 Abs. 1 NIS-2-Richtlinie durchgeführten koordinierten Risikobewertungen;

- e) Sicherheitsmaßnahmen bei Erwerb, Entwicklung und Wartung von Netz- und Informationssystemen, einschließlich Management und Offenlegung von Schwachstellen;
- f) Konzepte und Verfahren zur Bewertung der Wirksamkeit von Risikomanagementmaßnahmen im Bereich der Cybersicherheit;
- g) grundlegende Verfahren im Bereich der Cyberhygiene und Schulungen im Bereich der Cybersicherheit;
- h) Konzepte und Verfahren für den Einsatz von Kryptografie und gegebenenfalls Verschlüsselung;
- i) Sicherheit des Personals, Konzepte für die Zugriffskontrolle und Management von Anlagen;
- j) Verwendung von Lösungen zur Multi-Faktor-Authentifizierung oder kontinuierlichen Authentifizierung, gesicherte Sprach-, Video- und Textkommunikation sowie gegebenenfalls gesicherte Notfallkommunikationssysteme innerhalb der Einrichtung.

(5) Die Cybersicherheitsbehörde ist ermächtigt, durch Verordnung nähere Anforderungen an die Risikomanagementmaßnahmen gemäß Abs. 4 festzulegen. Dabei kann die Cybersicherheitsbehörde insbesondere anordnen, dass die von der Europäischen Kommission auf Grundlage des Art. 21 Abs. 5 NIS-2-Richtlinie hinsichtlich einzelner Sektoren oder bestimmter Arten von Einrichtungen erlassenen Durchführungsrechtsakte zur Festlegung technischer und methodischer Anforderungen an Risikomanagementmaßnahmen auch auf andere Sektoren oder Arten von Einrichtungen anwendbar sind, wobei sektorspezifische Besonderheiten Berücksichtigung finden können.

Nachweis der Wirksamkeit von Risikomanagementmaßnahmen

§ 33. (1) Wesentliche und wichtige Einrichtungen haben innerhalb von zwölf Monaten nach Eintritt der Registrierungspflicht gemäß § 29 Abs. 2 der Cybersicherheitsbehörde Informationen hinsichtlich umgesetzter Risikomanagementmaßnahmen gemäß § 32, insbesondere betreffend die genutzten Netz- und Informationssysteme und die Sicherheit der Lieferketten sowie die Ergebnisse der durchgeführten Risikoanalyse, nach den Vorgaben der Cybersicherheitsbehörde in strukturierter Form zu übermitteln (Selbstdeklaration).

(2) Wesentliche und wichtige Einrichtungen haben innerhalb von zwei Jahren nach Aufforderung durch die Cybersicherheitsbehörde die technische, operative und organisatorische Umsetzung der Risikomanagementmaßnahmen gemäß § 32 durch eine von einer unabhängigen Stelle nach den Vorgaben der Cybersicherheitsbehörde sowie auf Basis der von der jeweiligen Einrichtung durchgeführten Risikoanalyse oder einer aufgrund sonstiger Risikoabwägungen durchgeführten Prüfung, die nicht länger als zwei Jahre zurückliegt, nachzuweisen, wobei der Nachweis der operativen sowie organisatorischen Umsetzung auch durch einschlägige gültige Zertifikate möglich ist. Davon abweichend haben wesentliche Einrichtungen die operative sowie organisatorische Umsetzung der Risikomanagementmaßnahmen innerhalb von zwei Monaten nach Aufforderung durch die Cybersicherheitsbehörde nachzuweisen. Für Aufforderungen in Bezug auf wichtige Einrichtungen gilt § 38 Abs. 2 sinngemäß. Die erstmalige Aufforderung kann frühestens nach Ablauf von zwei Jahren ab Inkrafttreten dieses Bundesgesetzes erfolgen.

(3) Zum Nachweis der Umsetzung der Risikomanagementmaßnahmen durch eine von einer unabhängigen Stelle durchgeführte Prüfung gemäß Abs. 2 hat die jeweilige Einrichtung der Cybersicherheitsbehörde einen von ihren Leitungsorganen sowie den eingesetzten unabhängigen Prüfern unterzeichneten Prüfbericht über die Umsetzung der Risikomanagementmaßnahmen einschließlich festgestellter Mängel und einen Maßnahmenplan zur Beseitigung der Mängel nach den Vorgaben der Cybersicherheitsbehörde in strukturierter Form zu übermitteln.

(4) Die Kosten von Prüfungen durch unabhängige Stellen sind von der geprüften Einrichtung zu tragen, es sei denn, die Cybersicherheitsbehörde trifft in hinreichend begründeten Fällen eine anderslautende Entscheidung.

(5) Wesentliche und wichtige Einrichtungen haben der Cybersicherheitsbehörde geplante Prüfungen durch unabhängige Stellen spätestens einen Monat im Voraus nach den Vorgaben der Cybersicherheitsbehörde durch Übermittlung eines Prüfplans, aus dem die Einzelheiten der beabsichtigten Prüfung hervorgehen, bekannt zu geben.

Berichtspflichten

§ 34. (1) Wesentliche und wichtige Einrichtungen haben dem für sie zuständigen sektorspezifischen CSIRT oder den für sie zuständigen sektorspezifischen CSIRTs, in Ermangelung eines solchen dem nationalen CSIRT, unverzüglich jeden erheblichen Cybersicherheitsvorfall (§ 35) zu melden. Das CSIRT leitet die Meldung unverzüglich an die Cybersicherheitsbehörde weiter.

(2) Für die Zwecke der Meldung gemäß Abs. 1 haben die betroffenen Einrichtungen dem CSIRT Folgendes zu übermitteln:

1. unverzüglich, in jedem Fall aber innerhalb von 24 Stunden nach Kenntnisnahme des erheblichen Cybersicherheitsvorfalls, eine Frühwarnung, in der gegebenenfalls angegeben wird, ob der Verdacht besteht, dass der erhebliche Cybersicherheitsvorfall auf rechtswidrige und schuldhaft Handlungen zurückzuführen ist oder grenzüberschreitende Auswirkungen haben könnte;
2. unverzüglich, in jedem Fall aber innerhalb von 72 Stunden nach Kenntnisnahme des erheblichen Cybersicherheitsvorfalls, eine Meldung über den Cybersicherheitsvorfall, in der gegebenenfalls die unter Z 1 genannten Informationen aktualisiert werden und eine erste Bewertung des erheblichen Cybersicherheitsvorfalls, einschließlich seines Schweregrads und seiner Auswirkungen, sowie gegebenenfalls die Kompromittierungsindikatoren angegeben werden;
3. auf Ersuchen eines CSIRTs oder gegebenenfalls der Cybersicherheitsbehörde einen Zwischenbericht über relevante Statusaktualisierungen;
4. spätestens einen Monat nach Übermittlung der Meldung des Cybersicherheitsvorfalls gemäß Z 2 einen Abschlussbericht, der Folgendes enthält:
 - a) eine ausführliche Beschreibung des Cybersicherheitsvorfalls, einschließlich seines Schweregrads und seiner Auswirkungen;
 - b) Angaben zur Art der Bedrohung und zu den zugrundeliegenden Ursachen, die wahrscheinlich den Cybersicherheitsvorfall ausgelöst haben;
 - c) Angaben zu den getroffenen und laufenden Abhilfemaßnahmen;
 - d) gegebenenfalls die grenzüberschreitenden Auswirkungen des Cybersicherheitsvorfalls;
5. soweit der Cybersicherheitsvorfall zum Zeitpunkt der Fälligkeit der Vorlage des Abschlussberichts gemäß Z 4 noch andauert, haben die betreffenden Einrichtungen bis zu diesem Zeitpunkt einen Fortschrittsbericht zu übermitteln, wobei der Abschlussbericht bis spätestens einen Monat nach Beendigung der Vorfallsbehandlung übermittelt werden muss.

Abweichend von Z 2 unterrichtet ein Vertrauensdiensteanbieter das CSIRT in Bezug auf erhebliche Cybersicherheitsvorfälle, die sich auf die Erbringung seiner Vertrauensdienste auswirken, unverzüglich, in jedem Fall aber innerhalb von 24 Stunden nach Kenntnisnahme des erheblichen Cybersicherheitsvorfalls. Zusätzlich haben die betroffenen Einrichtungen alle Informationen zu übermitteln, die es dem CSIRT und der Cybersicherheitsbehörde ermöglichen zu ermitteln, ob der Cybersicherheitsvorfall grenzübergreifende Auswirkungen hat.

(3) Soweit ein erheblicher Cybersicherheitsvorfall die Erbringung des jeweiligen Dienstes der betroffenen Einrichtung beeinträchtigt, hat die Einrichtung die Empfänger ihrer Dienste unverzüglich über diesen erheblichen Cybersicherheitsvorfall zu unterrichten und, soweit möglich, alle Maßnahmen oder Abhilfemaßnahmen mitzuteilen, die diese Empfänger als Reaktion auf diese Bedrohung ergreifen können.

(4) Das CSIRT hat der meldenden Einrichtung spätestens 24 Stunden nach Eingang der Frühwarnung gemäß Abs. 2 Z 1 eine Antwort zu übermitteln, einschließlich einer ersten Rückmeldung zu dem erheblichen Cybersicherheitsvorfall und, auf Ersuchen der Einrichtung, Orientierungshilfen oder operative Beratung für die Durchführung möglicher Abhilfemaßnahmen. Auf Ersuchen der betreffenden Einrichtung leistet das CSIRT zusätzliche technische Unterstützung. Wird bei dem erheblichen Cybersicherheitsvorfall ein strafrechtlich relevanter Hintergrund vermutet, gibt das CSIRT ferner Orientierungshilfen für die Meldung des Cybersicherheitsvorfalls an die Strafverfolgungsbehörden.

(5) Wenn der erhebliche Cybersicherheitsvorfall zwei oder mehr Mitgliedstaaten der Europäischen Union betrifft, hat die Cybersicherheitsbehörde im Wege der zentralen Anlaufstelle unverzüglich die zentralen Anlaufstellen der anderen betroffenen Mitgliedstaaten und die ENISA über den erheblichen Cybersicherheitsvorfall zu unterrichten. Diese Mitteilung hat die gemäß Abs. 2 erhaltenen Informationen zu enthalten.

(6) Nach Anhörung der von einem erheblichen Cybersicherheitsvorfall betroffenen Einrichtungen kann die Cybersicherheitsbehörde personenbezogene Daten nach erfolgter Interessenabwägung bezüglich der Auswirkungen auf die Betroffenen veröffentlichen, um die Öffentlichkeit über erhebliche Cybersicherheitsvorfälle zu unterrichten, sofern die Sensibilisierung der Öffentlichkeit zur Verhütung oder zur Bewältigung von erheblichen Cybersicherheitsvorfällen erforderlich ist, oder die Offenlegung des erheblichen Cybersicherheitsvorfalls auf sonstige Weise im öffentlichen Interesse liegt. Bei der Interessenabwägung ist darauf zu achten, dass nur jene personenbezogenen Daten veröffentlicht werden, die zum vorgenannten Zweck unbedingt erforderlich sind. Es ist auf den Verhältnismäßigkeitsgrundsatz

gemäß § 1 Abs. 2 DSG und auf den Grundsatz der Datenminimierung gemäß Art. 5 Abs. 1 lit. c DSGVO Bedacht zu nehmen.

(7) Die Cybersicherheitsbehörde hat jener Behörde, die in Umsetzung des Art. 9 der Richtlinie (EU) 2022/2557 national als zuständige Behörde benannt oder eingerichtet wurde, Informationen über erhebliche Cybersicherheitsvorfälle, erhebliche Cyberbedrohungen und Beinahe-Vorfälle zur Verfügung zu stellen, die gemäß Abs. 1 von Einrichtungen, die gemäß der Richtlinie (EU) 2022/2557 als kritische Einrichtungen gelten, gemeldet wurden. Dasselbe gilt für freiwillige Meldungen gemäß § 37.

(8) Die Cybersicherheitsbehörde hat der Regulierungsbehörde gemäß § 194 TKG 2021 und der KommAustria gemäß § 199 TKG 2021 Informationen über erhebliche Cybersicherheitsvorfälle, erhebliche Cyberbedrohungen und Beinahe-Vorfälle zur Verfügung zu stellen, die gemäß Abs. 1 von Anbietern öffentlicher elektronischer Kommunikationsnetze oder Anbietern öffentlich zugänglicher elektronischer Kommunikationsdienste gemeldet wurden. Dasselbe gilt für freiwillige Meldungen gemäß § 37.

(9) Die Cybersicherheitsbehörde hat dem Bundesminister für Inneres halbjährlich über eingetretene erhebliche Cybersicherheitsvorfälle einschließlich der gemäß den Abs. 1, 5, 7 und 8 sowie gemäß § 8a Abs. 3 des Gesundheitstelematikgesetzes 2012 (GTelG 2012), BGBl. I Nr. 111/2012, zur Verfügung gestellten Informationen und über freiwillige Meldungen gemäß § 37 zu berichten.

(10) Die Cybersicherheitsbehörde hat der ENISA im Wege der zentralen Anlaufstelle alle drei Monate einen zusammenfassenden Bericht über gemäß Abs. 1 gemeldete erhebliche Cybersicherheitsvorfälle sowie gemäß § 37 gemeldete erhebliche Cyberbedrohungen sowie Beinahe-Cybersicherheitsvorfälle zu übermitteln.

Erheblicher Cybersicherheitsvorfall

§ 35. (1) Ein Cybersicherheitsvorfall gilt als erheblich, wenn er

1. schwerwiegende Betriebsstörungen der erbrachten Dienste der Einrichtung oder schwerwiegende finanzielle Verluste für die betreffende Einrichtung verursacht hat oder verursachen kann;
2. andere natürliche oder juristische Personen durch erhebliche materielle oder immaterielle Schäden beeinträchtigt hat oder beeinträchtigen kann.

(2) Bei der Beurteilung, ob ein Cybersicherheitsvorfall als erheblich gemäß Abs. 1 einzustufen ist, sind folgende Kriterien zu berücksichtigen:

1. die Abhängigkeit anderer in **Anlage 1 und 2** angeführter Sektoren oder Teilsektoren oder Arten von Einrichtungen von dem von der Einrichtung erbrachten Dienst oder den von der Einrichtung erbrachten Diensten;
2. die möglichen Auswirkungen von Cybersicherheitsvorfällen auf die Umwelt, die öffentliche Ordnung und Sicherheit, die öffentliche Gesundheit oder die Gesundheit der Bevölkerung oder eines großen Personenkreises;
3. der Marktanteil der jeweiligen Einrichtung auf dem Markt für die betreffenden Dienste gemäß Abs. 1;
4. das geografische Gebiet, das von einem Cybersicherheitsvorfall betroffen sein könnte, einschließlich allfälliger grenzüberschreitender Auswirkungen, unter Berücksichtigung der Schwachstellen, die mit dem Grad der Isolierung bestimmter geografischer Gebiete verbunden sind;
5. die betroffenen Netz- und Informationssysteme und deren Bedeutung für die Erbringung der Dienste der jeweiligen Einrichtung, die Schwere und die technischen Merkmale der Cyberbedrohung und sämtliche dem Cybersicherheitsvorfall zugrundeliegende Schwachstellen, die ausgenutzt werden, sowie die Erfahrungen der Einrichtung mit ähnlichen Cybersicherheitsvorfällen;
6. gegebenenfalls unternehmens- und sektorspezifische Faktoren.

(3) Die Cybersicherheitsbehörde kann mit Verordnung weitere Kriterien und nähere Regelungen zu Abs. 2 für das Vorliegen eines erheblichen Cybersicherheitsvorfalls festlegen. Dabei können sektorspezifische Faktoren berücksichtigt werden.

3. Abschnitt

Informationsaustausch

Vereinbarungen über den Austausch von Informationen zur Cybersicherheit

§ 36. (1) Wesentliche und wichtige Einrichtungen sowie Einrichtungen, die nicht in den Anwendungsbereich dieses Bundesgesetzes fallen, können einander auf freiwilliger Basis relevante Cybersicherheitsinformationen, einschließlich Informationen über Cyberbedrohungen, Beinahe-Vorfälle, Schwachstellen, Techniken und Verfahren, Kompromittierungsindikatoren, gegnerische Taktiken, bedrohungsspezifische Informationen, Cybersicherheitswarnungen und Empfehlungen für die Konfiguration von Cybersicherheitsinstrumenten zur Aufdeckung von Cyberangriffen, übermitteln, sofern

1. dieser Informationsaustausch darauf abzielt, Cybersicherheitsvorfälle zu verhindern, aufzudecken, darauf zu reagieren oder sich von ihnen zu erholen oder ihre Folgen einzudämmen, oder
2. durch diesen Informationsaustausch das Cybersicherheitsniveau erhöht wird, insbesondere indem Aufklärungsarbeit über Cyberbedrohungen geleistet wird, die Fähigkeit solcher Bedrohungen, sich zu verbreiten, eingedämmt oder verhindert wird und eine Reihe von Abwehrkapazitäten, die Beseitigung und Offenlegung von Schwachstellen, Techniken zur Erkennung, Eindämmung und Verhütung von Bedrohungen, Eindämmungsstrategien, Reaktions- und Wiederherstellungsphasen unterstützt werden oder indem die gemeinsame Forschung im Bereich der Cyberbedrohungen zwischen öffentlichen und privaten Einrichtungen gefördert wird.

(2) Der Informationsaustausch zwischen den wesentlichen und wichtigen Einrichtungen und gegebenenfalls ihren Lieferanten oder Dienstleistern hat im Wege von Vereinbarungen über den Informationsaustausch im Bereich der Cybersicherheit unter Beachtung des potentiell sensiblen Charakters der ausgetauschten Informationen zu erfolgen. In diesen Vereinbarungen können operative Elemente, einschließlich die Nutzung spezieller IKT-Plattformen und Automatisierungsinstrumente, der Inhalt und die Bedingungen der Vereinbarungen über den Informationsaustausch bestimmt werden.

(3) Die Cybersicherheitsbehörde hat die Einrichtungen bei der Ausarbeitung von Vereinbarungen gemäß Abs. 2, insbesondere hinsichtlich der Anwendung der in § 15 Abs. 4 Z 8 genannten Konzepte, zu unterstützen.

(4) Wesentliche und wichtige Einrichtungen haben die Cybersicherheitsbehörde beim Abschluss von in Abs. 2 genannten Vereinbarungen oder über ihren Rücktritt von solchen Vereinbarungen zu unterrichten, sobald dieser wirksam wird.

Freiwillige Meldung relevanter Informationen

§ 37. (1) Einrichtungen der Sektoren nach **Anlage 1 und 2** können unabhängig von ihrer Berichtspflicht gemäß § 34 freiwillig Cybersicherheitsvorfälle, Cyberbedrohungen und Beinahe-Cybersicherheitsvorfälle an das für sie zuständige sektorale CSIRT, in Ermangelung eines solchen an das nationale CSIRT, melden, das die Meldungen zusammenfasst und an die Cybersicherheitsbehörde weiterleitet.

(2) Einrichtungen, die nicht in den Anwendungsbereich dieses Bundesgesetzes fallen, können ebenfalls auf freiwilliger Basis Cybersicherheitsvorfälle, Cyberbedrohungen und Beinahe-Cybersicherheitsvorfälle an das nationale CSIRT melden, das die Meldungen zusammenfasst und an die Cybersicherheitsbehörde weiterleitet.

(3) Eine freiwillige Meldung muss weder die Identität der Einrichtung noch Informationen, die auf diese schließen lassen, beinhalten.

4. Abschnitt

Aufsicht und Durchsetzung

Aufsichtsmaßnahmen in Bezug auf wesentliche und wichtige Einrichtungen

§ 38. (1) Die Cybersicherheitsbehörde ist in Wahrnehmung ihrer Aufsichtsaufgaben zur Einhaltung der sich aus diesem Bundesgesetz ergebenden Verpflichtungen in Bezug auf wesentliche Einrichtungen neben § 33 befugt, folgende Maßnahmen zu ergreifen:

1. die Durchführung von Kontrollen der Umsetzung der Risikomanagementmaßnahmen gemäß § 32 durch Einschau, insbesondere in die diesbezüglichen Netz- und Informationssysteme und Unterlagen vor Ort und aus der Ferne unter Mitwirkung der Einrichtung oder durch Begleitung

der Prüfungen durch unabhängige Stellen, jeweils nach vorangegangener Verständigung der betreffenden Einrichtung;

2. die Durchführung von Sicherheitsscans auf der Grundlage objektiver, nichtdiskriminierender, fairer und transparenter Risikobewertungskriterien, erforderlichenfalls in Zusammenarbeit mit der betreffenden Einrichtung;
3. die Anforderung von Informationen, die für die Bewertung der von der betreffenden Einrichtung umgesetzten Risikomanagementmaßnahmen gemäß § 32 erforderlich sind, einschließlich dokumentierter Cybersicherheitskonzepte, sowie der Einhaltung der Verpflichtungen zur Übermittlung von Informationen gemäß § 29;
4. die Anforderung des Zugangs zu Daten, Dokumenten und sonstigen Informationen, die zur Erfüllung der Aufsichtsaufgaben erforderlich sind;
5. die Ad-hoc-Prüfung einer wesentlichen Einrichtung, einschließlich solche, die aufgrund eines erheblichen Cybersicherheitsvorfalls oder Verstoßes gegen dieses Bundesgesetz durch diese Einrichtung gerechtfertigt sind oder der Überprüfung einer übermittelten Selbstdeklaration gemäß § 33 Abs. 1 dienen.

(2) Erlangt die Cybersicherheitsbehörde durch Nachweise, wie insbesondere die Selbstdeklaration gemäß § 33 Abs. 1, oder sonstige begründete Hinweise und Informationen davon Kenntnis, dass eine wichtige Einrichtung mutmaßlich ihren Verpflichtungen nach diesem Bundesgesetz, insbesondere den §§ 32 und 34, nicht nachkommt, kann sie auch gegenüber wichtigen Einrichtungen Aufsichtsmaßnahmen gemäß Abs. 1 Z 1 bis 4 setzen.

(3) Die Ausübung der Maßnahmen gemäß den Abs. 1 und 2 hat in dem unbedingt erforderlichen Ausmaß sowie unter möglichster Schonung der Rechte der betroffenen Einrichtung und Dritter sowie des Betriebs zu erfolgen.

Durchsetzungsmaßnahmen in Bezug auf wesentliche und wichtige Einrichtungen

§ 39. (1) Die Cybersicherheitsbehörde ist zur Sicherstellung der Einhaltung der sich aus diesem Bundesgesetz ergebenden Verpflichtungen gegenüber wesentlichen und wichtigen Einrichtungen befugt, mit Aufforderung unter Setzung einer angemessenen Frist Maßnahmen anzuordnen, wie etwa solche zur Verhütung oder Behebung eines Cybersicherheitsvorfalls, zur Behebung festgestellter Mängel oder zur Beendigung von Zuwiderhandlungen gegen Verpflichtungen nach diesem Bundesgesetz.

(2) Kommt die Einrichtung einer Aufforderung gemäß Abs. 1 nicht nach, hat die Cybersicherheitsbehörde die nachweisliche Umsetzung der jeweiligen Maßnahmen unter Setzung einer angemessenen Frist mit Bescheid aufzutragen.

(3) Zudem ist die Cybersicherheitsbehörde befugt, mit Bescheid

1. gegenüber wesentlichen und wichtigen Einrichtungen anzuordnen,
 - a) die potenziell von einer erheblichen Cyberbedrohung betroffenen Personen, einschließlich der Empfänger ihrer Dienste und sonstigen Tätigkeiten, über die Art der Bedrohung sowie über mögliche Abwehr- und Abhilfemaßnahmen zu unterrichten, und
 - b) einzelne Aspekte der seitens der Cybersicherheitsbehörde aufgezeigten nicht eingehaltenen sich aus diesem Bundesgesetz ergebenden Verpflichtungen öffentlich bekannt zu machen, sofern dies erforderlich ist, um das damit verbundene Risiko auf ein vertretbares Ausmaß zu reduzieren, sowie
2. gegenüber wesentlichen Einrichtungen für einen bestimmten Zeitraum einen mit genau festgelegten Aufgaben betrauten Überwachungsbeauftragten zur Überwachung der Anforderungen gemäß den §§ 32 und 34 zu benennen, um die Umsetzung der gemäß Abs. 2 mit Bescheid angeordneten Maßnahmen sicherzustellen. Die Cybersicherheitsbehörde hat die Aufgaben des Überwachungsbeauftragten auf jenen Umfang zu beschränken, der für die Einhaltung der Anforderungen an die Umsetzung der Risikomanagementmaßnahmen und der Berichtspflichten der wesentlichen Einrichtung unbedingt erforderlich ist.

(4) Kommt eine wesentliche Einrichtung dem Bescheid gemäß Abs. 2 nicht fristgerecht und nachweislich nach, ist die Cybersicherheitsbehörde befugt,

1. die zuständige Behörde zu ersuchen, die Zertifizierung oder Genehmigung für einen Teil oder alle von der Einrichtung erbrachten einschlägigen Dienste oder Tätigkeiten vorübergehend auszusetzen oder die nationale Behörde für die Cybersicherheitszertifizierung gemäß Art. 58 der Verordnung (EU) 2019/881 über die ENISA (Agentur der Europäischen Union für Cybersicherheit) und über die Zertifizierung der Cybersicherheit von Informations- und Kommunikationstechnik und zur Aufhebung der Verordnung (EU) Nr. 526/2013 (Rechtsakt zur

Cybersicherheit), ABl. Nr. L 151 vom 07.06.2019 S. 15, oder eine Konformitätsbewertungsstelle zu ersuchen, die Zertifizierung oder Genehmigung vorübergehend auszusetzen;

2. Leitungsorganen einer wesentlichen Einrichtung, einschließlich ihrer rechtlichen Vertreter, mit Bescheid vorübergehend zu untersagen, Leitungsaufgaben in dieser wesentlichen Einrichtung wahrzunehmen. Dieser Bescheid sowie dessen Aufhebung ist von der Cybersicherheitsbehörde dem Firmenbuchgericht zur Eintragung in das Firmenbuch zu übermitteln.

(5) Die gemäß Abs. 4 verhängten vorübergehenden Aussetzungen und Untersagungen sind von der zuständigen Behörde oder der Cybersicherheitsbehörde unverzüglich aufzuheben, sobald die betreffende wesentliche Einrichtung nachweislich die gemäß Abs. 2 angeordneten Maßnahmen ergriffen hat.

(6) Die in Abs. 4 vorgesehenen Durchsetzungsmaßnahmen finden keine Anwendung auf Behörden und sonstige Stellen der öffentlichen Verwaltung, einschließlich der Gebietskörperschaften sowie in Formen des Privatrechts eingerichtete Stellen der öffentlichen Verwaltung.

(7) Bei der Ergreifung von Durchsetzungsmaßnahmen gemäß den Abs. 1 bis 4 ist den Umständen des Einzelfalls Rechnung zu tragen und dabei zumindest Folgendes gebührend zu berücksichtigen:

1. die Schwere des Verstoßes und die Wichtigkeit der Bestimmungen, gegen die verstoßen wurde, wobei insbesondere Folgendes immer als schwerer Verstoß anzusehen ist:
 - a) wiederholte Verstöße;
 - b) eine unterlassene Meldung oder Behebung von erheblichen Cybersicherheitsvorfällen;
 - c) eine Nichtbehebung von Mängeln nach verbindlicher Anweisung der Cybersicherheitsbehörde;
 - d) eine willentliche Behinderung von Prüfungen oder Überwachungstätigkeiten, die nach der Feststellung eines Verstoßes von der Cybersicherheitsbehörde angeordnet wurden, sowie
 - e) eine bewusste Übermittlung falscher oder grob verfälschender Informationen in Bezug auf die Umsetzung der Risikomanagementmaßnahmen oder Berichtspflichten gemäß den §§ 32 und 34;
2. die Dauer des Verstoßes;
3. einschlägige frühere Verstöße der betreffenden Einrichtung;
4. der verursachte materielle oder immaterielle Schaden, darunter finanzieller oder wirtschaftlicher Verlust, Auswirkungen auf andere Dienste und die Zahl der betroffenen Nutzer;
5. der etwaige Vorsatz oder die etwaige Fahrlässigkeit jener Person, die den Verstoß verursacht hat;
6. die von der Einrichtung umgesetzten Risikomanagementmaßnahmen zur Verhinderung oder Minderung des materiellen oder immateriellen Schadens;
7. die Einhaltung genehmigter Verhaltensregeln oder genehmigter Zertifizierungsverfahren;
8. der Umfang der Zusammenarbeit der verantwortlichen natürlichen oder juristischen Personen mit der Cybersicherheitsbehörde.

(8) Liegt der Verdacht einer Verwaltungsübertretung gemäß § 45 Abs. 1 oder 4 vor, hat die Cybersicherheitsbehörde geeignete Durchsetzungsmaßnahmen gemäß den Abs. 1 bis 4 zu ergreifen.

(9) Die Cybersicherheitsbehörde hat dem Bundesminister für Inneres halbjährlich über die ergriffenen Aufsichts- und Durchsetzungsmaßnahmen zu berichten.

Nutzung der europäischen Schemata für die Cybersicherheitszertifizierung

§ 40. Die Cybersicherheitsbehörde kann wesentliche und wichtige Einrichtungen dazu verpflichten, spezifische IKT-Produkte, -Dienste und -Prozesse zu verwenden, die von der wesentlichen oder wichtigen Einrichtung entwickelt oder von Dritten beschafft werden und die im Rahmen europäischer Schemata für die Cybersicherheitszertifizierung, die gemäß Art. 49 der Verordnung (EU) 2019/881 angenommen wurden, zertifiziert sind, um die Erfüllung bestimmter in § 32 genannter Anforderungen nachzuweisen. In diesem Zusammenhang hat die Cybersicherheitsbehörde mit der nationalen Behörde für die Cybersicherheitszertifizierung zusammenzuarbeiten.

Beschwerdeverfahren

§ 41. (1) Gegen Bescheide der Cybersicherheitsbehörde und wegen Verletzung ihrer Entscheidungspflicht kann Beschwerde an das Bundesverwaltungsgericht erhoben werden.

(2) Gegen Bescheide der Bezirksverwaltungsbehörden und wegen Verletzung ihrer Entscheidungspflicht in Verwaltungssachen kann Beschwerde an die Verwaltungsgerichte der Länder erhoben werden.

4. Hauptstück Datenschutz

Datenverarbeitung

§ 42. (1) Der Bundeskanzler, der Bundesminister für Inneres, die Cybersicherheitsbehörde, der Bundesminister für Landesverteidigung, der Bundesminister für europäische und internationale Angelegenheiten und die CSIRTs sind jeweils als Verantwortliche gemäß Art. 4 Z 7 DSGVO und § 36 Abs. 2 Z 8 DSG berechtigt, zur Gewährleistung eines hohen Cybersicherheitsniveaus von Netz- und Informationssystemen bei der Wahrnehmung ihrer Aufgaben nach diesem Bundesgesetz sowie zum Schutz vor und der Abwehr von Gefahren für die öffentliche Sicherheit die erforderlichen personenbezogenen Daten gemäß Art. 4 Z 1 DSGVO und § 36 Abs. 2 Z 1 DSG zu verarbeiten.

(2) Dies sind folgende personenbezogene Daten:

1. Kontakt- und Identitätsdaten von Teilnehmern und ihren Organisationseinheiten, die zur Ermöglichung und im Zuge der Teilnahme an den Koordinierungsstrukturen zu organisatorischen Zwecken erforderlich sind;
2. Kontakt- und Identitätsdaten sowie technische Daten von Personen oder juristischen Personen, die in Zusammenhang mit Risiken, Cyberbedrohungen, erheblichen Cyberbedrohungen, Beinahe-Cybersicherheitsvorfällen, Cybersicherheitsvorfällen und Cybersicherheitsvorfällen großen Ausmaßes stehen, zum Zweck der Erörterung und Aktualisierung des von der Cybersicherheitsbehörde erstellten Lagebildes und zur Erörterung der Erkenntnisse, die gemäß § 17 gewonnen wurden, erforderlich sind;
3. Kontakt- und Identitätsdaten sowie technische Daten von Dritten, die an einem Geschäftsfall mitwirken oder davon betroffen sind.

(3) Der Bundeskanzler, der Bundesminister für Inneres, die Cybersicherheitsbehörde und der Bundesminister für Landesverteidigung sind zum Zweck der Analyse und Bewältigung von Risiken, Cyberbedrohungen, erheblichen Cyberbedrohungen, Beinahe-Cybersicherheitsvorfällen, Cybersicherheitsvorfällen und Cybersicherheitsvorfällen großen Ausmaßes berechtigt, über die in Abs. 2 genannten Daten hinaus folgende personenbezogene Daten zu verarbeiten:

1. Kontakt- und Identitätsdaten sowie technische Daten des Melders und der Kontaktperson;
2. Kontakt- und Identitätsdaten sowie technische Daten von Personen oder juristischen Personen, die mit einer Meldung zu einem Risiko, einer Cyberbedrohung, einer erheblichen Cyberbedrohung, einem Beinahe-Cybersicherheitsvorfall, einem Cybersicherheitsvorfall oder einem Cybersicherheitsvorfall großen Ausmaßes in Zusammenhang stehen, wie insbesondere Opfer und Angreifer.

(4) Die Cybersicherheitsbehörde ist zur Erfüllung ihrer Aufgaben gemäß § 4 berechtigt, über die in Abs. 2 und 3 genannten Daten hinaus folgende personenbezogenen Daten zu verarbeiten:

1. Kontakt- und Identitätsdaten sowie technische Daten von Einrichtungen, ferner deren unternehmensbezogene Daten zum Zweck der Einstufung als wesentliche oder wichtige Einrichtung und zur Führung des Registers gemäß § 29;
2. Kontakt- und Identitätsdaten sowie technische Daten von Domännennamen-Registrierungsdiensten, CSIRTs und von zuständigen Behörden und Stellen anderer Mitgliedstaaten der Europäischen Union;
3. Kontakt- und Identitätsdaten sowie technische Daten von Personen oder juristischen Personen, die mit einer Meldung zu einem Risiko, einer Cyberbedrohung, einer erheblichen Cyberbedrohung, einem Beinahe-Cybersicherheitsvorfall, einem Cybersicherheitsvorfall oder einem Cybersicherheitsvorfall großen Ausmaßes in Zusammenhang stehen, wie insbesondere Opfer und Angreifer;
4. Kontakt- und Identitätsdaten von Teilnehmern und ihren Organisationseinheiten, die zur Ermöglichung und im Zuge der Teilnahme an EU-weiten, internationalen und nationalen Gremien betreffend die Gewährleistung eines hohen Cybersicherheitsniveaus von Netz- und Informationssystemen erforderlich sind.

(5) Die Cybersicherheitsbehörde ist zur Erfüllung ihrer Aufgaben gemäß § 4 Z 5, 6, 12 und 15 berechtigt, über die in Abs. 2 bis 4 genannten Daten hinaus folgende personenbezogenen Daten zu verarbeiten:

1. Kontakt- und Identitätsdaten sowie technische Daten von öffentlichen und privaten Interessenträgern für die Erstellung des nationalen Plans gemäß § 16 Abs. 3,

2. Kontakt- und Identitätsdaten von Personen und juristischen Personen sowie technische Daten, die für die Wahrnehmung der Aufgaben des nationalen Koordinierungszentrums für Cybersicherheit erforderlich sind;
3. Kontakt- und Identitätsdaten sowie technische Daten unabhängiger Stellen und unabhängiger Prüfer sowie entsprechender Zulassungswerber;
4. technische Daten von natürlichen oder juristischen Personen, die im Rahmen des § 17 ermittelt wurden.

(6) CSIRTs sind zur Wahrnehmung ihrer Aufgaben gemäß § 8 berechtigt, personenbezogene Daten gemäß den Abs. 2 bis 4 zu verarbeiten, soweit dies zur Erfüllung ihrer Aufgaben erforderlich ist. Das nationale CSIRT ist überdies zum Zweck der Führung der koordinierten Offenlegung von Schwachstellen berechtigt, Kontakt- und Identitätsdaten sowie technische Daten der meldenden natürlichen oder juristischen Person, des Herstellers oder Anbieters der potenziell gefährdeten IKT-Produkte oder IKT-Dienste sowie die hiervon betroffenen Einrichtungen zu verarbeiten.

(7) Besondere Kategorien personenbezogener Daten gemäß Art. 9 DSGVO und § 39 DSG sowie personenbezogene Daten über gerichtlich oder verwaltungsbehördlich strafbare Handlungen oder Unterlassungen, insbesondere auch über den Verdacht der Begehung von Straftaten, sowie über strafrechtliche Verurteilungen dürfen nur insoweit verarbeitet werden, als dies zum Zweck der Gewährleistung eines hohen Cybersicherheitsniveaus von Netz- und Informationssystemen und der Abwehr von Gefahren für die öffentliche Sicherheit unbedingt erforderlich ist.

(8) Für die Verarbeitungsvorgänge von personenbezogenen Daten sind Protokollaufzeichnungen jedenfalls betreffend die Erhebung, Abfrage, Übermittlung, Änderung und Löschung zu führen, drei Jahre aufzubewahren und danach zu löschen.

(9) Personenbezogene Daten sind unverzüglich zu löschen, wenn sie für die Zwecke, für die sie erhoben oder auf sonstige Weise verarbeitet wurden, nicht mehr notwendig sind. Nach Ablauf von fünf Jahren sind die Daten jedenfalls zu löschen.

(10) Hinsichtlich der Verarbeitung personenbezogener Daten gemäß dem 3. Abschnitt des 2. Hauptstücks, dem 1., 2. und 4. Abschnitt des 3. Hauptstücks besteht kein Widerspruchsrecht gemäß Art. 21 DSGVO sowie kein Recht auf Einschränkung der Verarbeitung gemäß Art. 18 DSGVO oder § 45 DSG.

(11) Der zuständige Datenschutzbeauftragte hat halbjährlich einen zusammenfassenden Bericht über die Datenverarbeitungen bis spätestens sechs Monate nach Ende des Berichtszeitraums auf der Homepage des Bundesministeriums für Inneres zu veröffentlichen.

Datenübermittlung

§ 43. (1) Die Cybersicherheitsbehörde, der Bundesminister für Inneres, der Bundeskanzler, der Bundesminister für Landesverteidigung und der Bundesminister für europäische und internationale Angelegenheiten sind ermächtigt, die aufgrund der Wahrnehmung ihrer Aufgaben nach diesem Bundesgesetz verarbeiteten Daten

1. einander für Zwecke der ihnen nach diesem Bundesgesetz zugewiesenen Aufgaben,
2. den Mitgliedern der OpKoord (§ 14) für Zwecke der ihr nach diesem Bundesgesetz zugewiesenen Aufgaben,
3. an militärische Behörden für Zwecke der militärischen Landesverteidigung gemäß Art. 79 Abs. 1 B-VG, soweit dies eine wesentliche Voraussetzung zur Wahrnehmung einer ihnen gesetzlich übertragenen Aufgabe ist,
4. an Sicherheitsbehörden für Zwecke der Sicherheitspolizei und Strafrechtspflege, soweit dies eine wesentliche Voraussetzung zur Wahrnehmung einer ihnen gesetzlich übertragenen Aufgabe ist,
5. an Staatsanwaltschaften und ordentliche Gerichte für Zwecke der Strafrechtspflege, soweit dies eine wesentliche Voraussetzung zur Wahrnehmung einer ihnen gesetzlich übertragenen Aufgabe ist, sowie
6. an jene Behörden, die in Umsetzung des Art. 9 der Richtlinie (EU) 2022/2557 innerstaatlich als zuständige Behörden benannt oder eingerichtet wurden und an sonstige inländische Behörden, soweit dies jeweils eine wesentliche Voraussetzung zur Wahrnehmung einer ihnen gesetzlich übertragenen Aufgabe ist,

zu übermitteln.

(2) Die Cybersicherheitsbehörde ist berechtigt, Daten gemäß § 42 Abs. 2 bis 5 an ausländische Sicherheitsbehörden und Sicherheitsorganisationen gemäß § 2 Abs. 2 und 3 des Polizeikooperationsgesetzes (PolKG), BGBl. I Nr. 104/1997, sowie an Organe der Europäischen Union

oder der Vereinten Nationen entsprechend den Bestimmungen über die internationale polizeiliche Amtshilfe zu übermitteln.

(3) Die Cybersicherheitsbehörde ist zudem berechtigt, Daten, die sie zur Wahrnehmung ihrer Aufgaben nach diesem Bundesgesetz verarbeitet, an wesentliche und wichtige Einrichtungen und mit diesen im Rahmen des Schutzes ihrer Netz- und Informationssysteme zusammenarbeitende Dritte sowie an sonstige Einrichtungen, die von einem Risiko oder Cybersicherheitsvorfall betroffen sind, an CSIRTs zur Wahrnehmung ihrer Aufgaben gemäß § 8 Abs. 1, an die ENISA gemäß § 5 Abs. 2 Z 2, § 29 Abs. 5 und § 34 Abs. 5, an die zentralen Anlaufstellen der von einem erheblichen Cybersicherheitsvorfall betroffenen Mitgliedstaaten der Europäischen Union gemäß § 34 Abs. 5, an die zuständigen Behörden in der Europäischen Union gemäß § 22, an die Europäische Kommission gemäß § 8 Abs. 10 und an die Europäische Kommission und EU-CyCLONE gemäß § 16 zu übermitteln.

(4) Die CSIRTs sind berechtigt, Daten zur Erfüllung ihrer Aufgaben nach diesem Bundesgesetz einander, an wesentliche und wichtige Einrichtungen gemäß § 8 Abs. 1, 2 und 8 sowie § 34 Abs. 4, an sonstige Einrichtungen und Personen gemäß § 8 Abs. 11, an Teilnehmer des CSIRTs-Netzwerks gemäß § 8 Abs. 1 Z 6 und § 11 Abs. 3, an nationale CSIRTs von Drittländern oder gleichwertige Stellen oder Sicherheitsdienstleister gemäß § 8 Abs. 9 sowie an inländische Behörden, soweit dies eine wesentliche Voraussetzung zur Wahrnehmung einer ihnen gesetzlich übertragenen Aufgabe ist, zu übermitteln.

5. Hauptstück

Strafbestimmungen

Allgemeine Bedingungen für die Verhängung von Geldstrafen

§ 44. (1) Den Bezirksverwaltungsbehörden obliegt die Verhängung von Verwaltungsstrafen gemäß § 45. Die Cybersicherheitsbehörde hat der zuständigen Bezirksverwaltungsbehörde den Verdacht einer Verwaltungsübertretung gemäß § 45 Abs. 1 oder 4 anzuzeigen. Die Bezirksverwaltungsbehörde hat der Cybersicherheitsbehörde einen jährlichen Bericht über eingeleitete Verwaltungsstrafverfahren sowie die Gründe für die Nichteinleitung oder Einstellung von Verwaltungsstrafverfahren nach standardisierten Vorgaben bis zum 31. März des Folgejahres zu übermitteln.

(2) Die Bezirksverwaltungsbehörde ist verpflichtet, die Cybersicherheitsbehörde über von Amts wegen eingeleitete Verwaltungsstrafverfahren wegen des Verdachts einer Verwaltungsübertretung gemäß § 45 Abs. 1 oder 4 zu informieren.

(3) Die Bezirksverwaltungsbehörde kann Geldstrafen gegen eine juristische Person oder eingetragene Personengesellschaft verhängen, wenn Verwaltungsübertretungen gemäß § 45 Abs. 1 und 4 durch Personen begangen wurden, die entweder allein oder als Teil eines Organs der juristischen Person oder der eingetragenen Personengesellschaft gehandelt haben und eine Führungsposition innerhalb einer juristischen Person oder eingetragenen Personengesellschaft aufgrund

1. der Befugnis zur Vertretung der juristischen Person oder der eingetragenen Personengesellschaft,
2. der Befugnis, Entscheidungen im Namen der juristischen Person oder der eingetragenen Personengesellschaft zu treffen, oder
3. einer Kontrollbefugnis innerhalb der juristischen Person oder der eingetragenen Personengesellschaft

innehaben.

(4) Juristische Personen oder eingetragene Personengesellschaften können wegen Verwaltungsübertretungen gemäß § 45 Abs. 1 und 4 auch verantwortlich gemacht werden, wenn mangelnde Überwachung oder Kontrolle durch eine in Abs. 3 genannte Person die Begehung dieser Verstöße durch eine für die juristische Person oder eingetragene Personengesellschaft tätige Person ermöglicht hat.

(5) Von der Bestrafung eines Verantwortlichen gemäß § 9 des Verwaltungsstrafgesetzes 1991 (VStG), BGBl. Nr. 52/1991, ist abzusehen, wenn für denselben Verstoß bereits eine Verwaltungsstrafe gegen die juristische Person oder eingetragene Personengesellschaft verhängt wird.

(6) Bei der Strafbemessung sind insbesondere die in § 39 Abs. 7 genannten Umstände zu berücksichtigen.

(7) Hat die Datenschutzbehörde bereits eine Geldbuße gemäß Art. 58 Abs. 2 lit. i DSGVO für einen Verstoß verhängt, darf die Bezirksverwaltungsbehörde keine Geldstrafe nach dem vorliegenden Bundesgesetz verhängen, wenn dem Verstoß dasselbe Verhalten zu Grunde liegt, das Gegenstand der Geldbuße nach Art. 58 Abs. 2 lit. i DSGVO war.

Verwaltungsstrafbestimmungen

§ 45. (1) Wer

1. seiner Verpflichtung, Cybersicherheitsschulungen für Leitungsorgane gemäß § 31 Abs. 2 vorzusehen, nicht nachkommt,
2. seiner Verpflichtung, Cybersicherheitsschulungen für Mitarbeiter (Arbeitnehmer) gemäß § 31 Abs. 2 zweiter Satz vorzusehen, nicht nachkommt,
3. Risikomanagementmaßnahmen gemäß § 32 nicht umsetzt, soweit dieser Umstand der Cybersicherheitsbehörde nicht nur aufgrund einer Selbstdeklaration gemäß § 33 Abs. 1 bekanntgeworden ist,
4. seiner Verpflichtung zur Meldung eines erheblichen Cybersicherheitsvorfalls gemäß § 34 Abs. 1 und 2 sowie den damit zusammenhängenden Berichtspflichten nicht entspricht,
5. seiner Verpflichtung zur unverzüglichen Unterrichtung der Empfänger der Dienste einer wesentlichen oder wichtigen Einrichtung gemäß § 34 Abs. 3 nicht entspricht, oder
6. den gemäß § 39 Abs. 2 angeordneten Durchsetzungsmaßnahmen nicht fristgerecht nachkommt, sofern nicht wegen desselben zugrundeliegenden Sachverhalts eine Strafbarkeit nach den Abs. 1 oder 4 besteht,

begeht eine Verwaltungsübertretung und ist mit einer Geldstrafe nach Maßgabe der Abs. 2 und 3 zu bestrafen.

(2) Wer als wesentliche Einrichtung (§ 24 Abs. 1) eine Verwaltungsübertretung gemäß Abs. 1 begeht, ist mit Geldstrafe in Höhe von bis zu 10 000 000 EUR oder bis zu 2 % des gesamten weltweiten im vorangegangenen Geschäftsjahr getätigten Umsatzes des Unternehmens, dem die wesentliche Einrichtung angehört, je nachdem, welcher Betrag höher ist, zu bestrafen.

(3) Wer als wichtige Einrichtung (§ 24 Abs. 2) eine Verwaltungsübertretung gemäß Abs. 1 begeht, ist mit Geldstrafe in Höhe von bis zu 7 000 000 EUR oder bis zu 1,4 % des gesamten weltweiten im vorangegangenen Geschäftsjahr getätigten Umsatzes des Unternehmens, dem die wichtige Einrichtung angehört, je nachdem, welcher Betrag höher ist, zu bestrafen.

(4) Wer

1. sich bei der Cybersicherheitsbehörde nicht fristgerecht gemäß § 29 Abs. 3 registriert oder im Zuge der Registrierung wesentlich falsche oder unvollständige Angaben übermittelt,
2. der Cybersicherheitsbehörde Änderungen gemäß § 29 Abs. 4 nicht im dort vorgegebenen Zeitraum bekannt gibt,
3. seiner Verpflichtung zur Führung einer Datenbank gemäß § 30 Abs. 1 nicht nachkommt,
4. entgegen § 30 Abs. 3 über keine Vorgaben und Verfahren, einschließlich Überprüfungsverfahren, verfügt oder diese Vorgaben und Verfahren nicht öffentlich zugänglich macht,
5. entgegen § 30 Abs. 4 nicht unverzüglich nach der Registrierung eines Domänenamens die nicht personenbezogenen Domänennamen-Registrierungsdaten öffentlich zugänglich macht,
6. entgegen § 30 Abs. 5 trotz rechtmäßigen und begründeten Antrags keinen Zugang zu den Domänennamen-Registrierungsdaten gewährt, alle Anträge auf Zugang nicht unverzüglich, längstens jedoch innerhalb von 72 Stunden nach Eingang des jeweiligen Antrags, beantwortet oder die Vorgaben und Verfahren im Hinblick auf die Offenlegung solcher Daten nicht öffentlich zugänglich macht,
7. entgegen § 33 Abs. 1 seiner Verpflichtung zur Selbstdeklaration nicht fristgerecht nachkommt,
8. in einer Selbstdeklaration gemäß § 33 Abs. 1 wesentlich falsche Angaben über die Umsetzung von Risikomanagementmaßnahmen macht,
9. entgegen § 33 Abs. 3 seiner Verpflichtung zur Übermittlung eines Prüfberichts nicht fristgerecht nachkommt,
10. entgegen § 33 Abs. 5 der Cybersicherheitsbehörde die geplanten Prüfungen nicht fristgerecht bekanntgibt,
11. seiner Verpflichtung zur Bekanntgabe von Abschlüssen sowie Rücktritten von Vereinbarungen zum Informationsaustausch gemäß § 36 Abs. 4 nicht entspricht,
12. die Durchführung einer Kontrolle der jeweiligen Einrichtung gemäß § 38 Abs. 1 Z 1 be- oder verhindert,
13. die Durchführung von Sicherheitsscans betreffend die jeweilige Einrichtung gemäß § 38 Abs. 1 Z 2 be- oder verhindert,

14. seiner Verpflichtung zur Bereitstellung von Informationen einschließlich dokumentierter Sicherheitskonzepte gemäß § 38 Abs. 1 Z 3 nicht entspricht,
15. seiner Verpflichtung zur Gewährung des Zugangs zu Daten, Dokumenten oder sonstigen Informationen auf Anforderung gemäß § 38 Abs. 1 Z 4 nicht entspricht,
16. die Durchführung einer Ad-hoc-Prüfung der jeweiligen Einrichtung gemäß § 38 Abs. 1 Z 5 be- oder verhindert,
17. den gemäß § 39 Abs. 3 Z 1 lit. a und b angeordneten Maßnahmen nicht fristgerecht nachkommt,
18. den Überwachungsbeauftragten gemäß § 39 Abs. 3 Z 2 bei seiner Tätigkeit behindert oder
19. seiner Verpflichtung zur Verwendung spezieller IKT-Produkte, -Dienste und -Prozesse gemäß § 40 nicht nachkommt,

ist mit Geldstrafe in Höhe von bis zu 50 000 EUR und im Wiederholungsfall bis zu 100 000 EUR zu bestrafen.

Nichteinhaltung von Verpflichtungen durch Stellen der öffentlichen Verwaltung

§ 46. (1) Die Cybersicherheitsbehörde hat der zuständigen Bezirksverwaltungsbehörde die Nichteinhaltung der sich aus diesem Bundesgesetz ergebenden Verpflichtungen durch Behörden und sonstige Stellen der öffentlichen Verwaltung, einschließlich der Gebietskörperschaften sowie in Formen des Privatrechts eingerichtete Stellen der öffentlichen Verwaltung, anzuzeigen. § 44 Abs. 1 zweiter Satz gilt.

(2) (**Verfassungsbestimmung**) Die Bezirksverwaltungsbehörde hat abweichend von § 45 die Nichteinhaltung der sich aus diesem Bundesgesetz ergebenden Verpflichtungen durch als wesentliche oder wichtige Einrichtungen geltende Behörden und sonstige Stellen der öffentlichen Verwaltung, einschließlich der Gebietskörperschaften sowie in Formen des Privatrechts eingerichtete Stellen der öffentlichen Verwaltung, mit Bescheid festzustellen und eine angemessene Frist zur Herstellung des rechtmäßigen Zustandes anzuordnen. Wird der rechtmäßige Zustand nicht fristgerecht hergestellt, hat die Bezirksverwaltungsbehörde nach Rechtskraft des Bescheides die Nichteinhaltung dieser Verpflichtungen in einer allgemeinen Weise zu veröffentlichen, die geeignet scheint, einen möglichst weiten Personenkreis zu erreichen, wobei vor Veröffentlichung den jeweiligen Behörden und sonstigen Stellen der öffentlichen Verwaltung Gelegenheit zur Stellungnahme innerhalb einer angemessenen Frist zu geben ist. Die Veröffentlichung darf nur insoweit erfolgen, als diese keine Gefahr für die öffentliche Ordnung oder Sicherheit oder für die nationale Sicherheit einschließlich der militärischen Landesverteidigung darstellt und keine schutzwürdigen Interessen wesentlicher und wichtiger Einrichtungen beeinträchtigt.

6. Hauptstück

Schlussbestimmungen

Personenbezogene Bezeichnungen

§ 47. Alle in diesem Bundesgesetz verwendeten personenbezogenen Bezeichnungen gelten gleichermaßen für alle Geschlechter. Bei der Anwendung der Bezeichnung auf bestimmte natürliche Personen ist die jeweils geschlechtsspezifische Form zu verwenden.

Durchführung und Umsetzung von Rechtsakten der Europäischen Union

§ 48. Durch dieses Bundesgesetz werden

1. die Richtlinie (EU) 2022/2555 über Maßnahmen für ein hohes gemeinsames Cybersicherheitsniveau in der Union, zur Änderung der Verordnung (EU) Nr. 910/2014 und der Richtlinie (EU) 2018/1972 sowie zur Aufhebung der Richtlinie (EU) 2016/1148 (NIS-2-Richtlinie), ABl. Nr. L 333 vom 27.12.2022 S. 80, umgesetzt;
2. die Verordnung (EU) 2021/887 zur Einrichtung des Europäischen Kompetenzzentrums für Industrie, Technologie und Forschung im Bereich der Cybersicherheit und des Netzwerks nationaler Koordinierungszentren, ABl. Nr. L 202 vom 08.06.2021 S. 1, durchgeführt.

Verweisungen

§ 49. Verweisungen in diesem Bundesgesetz auf andere Bundesgesetze sind als Verweisungen auf die jeweils geltende Fassung zu verstehen, soweit nichts anderes angeordnet wird.

Vollziehung

§ 50. Mit der Vollziehung dieses Bundesgesetzes sind betraut

1. hinsichtlich des § 6 Abs. 2, soweit es sich um Gebühren handelt, der Bundesminister für Finanzen und soweit es sich um Verwaltungsabgaben des Bundes handelt, die Bundesregierung;

2. hinsichtlich des § 15 die Bundesregierung;
3. hinsichtlich des § 13 der Bundesminister für Inneres gemeinsam mit dem Bundeskanzler und dem Bundesminister für Landesverteidigung;
4. hinsichtlich des § 14 der Bundesminister für Inneres gemeinsam mit dem Bundeskanzler, dem Bundesminister für Landesverteidigung und dem Bundesminister für europäische und internationale Angelegenheiten;
5. hinsichtlich der übrigen Bestimmungen der Bundesminister für Inneres.

Inkrafttretens-, Außerkrafttretens- und Übergangsbestimmungen

§ 51. (1) (Verfassungsbestimmung) Nach Ablauf von neun Monaten nach der Kundmachung dieses Bundesgesetzes mit dem nächstfolgenden Monatsersten treten § 1 und § 46 Abs. 2 in Kraft; gleichzeitig tritt § 1 des Netz- und Informationssystemsicherheitsgesetzes (NISG), BGBl. I Nr. 111/2018, außer Kraft.

(2) Nach Ablauf von neun Monaten nach der Kundmachung dieses Bundesgesetzes mit dem nächstfolgenden Monatsersten treten das Inhaltsverzeichnis, die Hauptstückbezeichnungen, die Hauptstücküberschriften, die Abschnittsbezeichnungen, die Abschnittsüberschriften, die Paragraphenüberschriften, die §§ 2 bis 45, § 46 Abs. 1 sowie die §§ 47 bis 50 sowie die Anlagen 1 und 2 in Kraft. Gleichzeitig treten das Inhaltsverzeichnis, die Abschnittsbezeichnungen, die Abschnittsüberschriften und die Paragraphenüberschriften des NISG, die §§ 2 bis 31 NISG sowie die Netz- und Informationssystemsicherheitsverordnung (NISV), BGBl. II Nr. 215/2019, und die Verordnung über qualifizierte Stellen (QuaStEV), BGBl. II Nr. 226/2019, außer Kraft.

(3) Verordnungen auf Grund dieses Bundesgesetzes können bereits ab dem auf seine Kundmachung folgenden Tag erlassen werden. Sie dürfen jedoch frühestens mit Inkrafttreten dieses Bundesgesetzes in Kraft gesetzt werden.

(4) Von dem der Kundmachung dieses Bundesgesetzes folgenden Tag an sind, soweit nicht bereits erfolgt, alle vorbereitenden Maßnahmen zu setzen, die für die Ermöglichung einer zeitgerechten Aufgabenwahrnehmung durch die Cybersicherheitsbehörde erforderlich sind.

(5) Bescheide, die gemäß § 15 Abs. 3, § 16 Abs. 1 und § 18 Abs. 1 NISG erlassen wurden, werden mit Inkrafttreten dieses Bundesgesetzes gegenstandslos, sofern nicht Abs. 6 oder Abs. 7 zur Anwendung gelangt.

(6) Das gemäß § 15 Abs. 3 NISG ermächtigte nationale CSIRT hat die Aufgaben gemäß § 8 Abs. 1 und 3 sowie § 11 bis zur Ermächtigung eines nationalen CSIRTs gemäß § 8 Abs. 2, längstens jedoch für einen Zeitraum von zwei Jahren ab Inkrafttreten dieses Bundesgesetzes, wahrzunehmen. § 8 Abs. 6 und § 10 gelten.

(7) Qualifizierte Stellen gemäß § 18 Abs. 1 NISG in der Fassung des Bundesgesetzes BGBl. I Nr. 111/2018 gelten ab Inkrafttreten dieses Bundesgesetzes bis nach Ablauf von zwölf Monaten nach Inkrafttreten der gemäß § 7 Abs. 6 zu erlassenden Verordnung als unabhängige Stellen gemäß § 7, wobei sie sich zur Prüfung der Umsetzung der Risikomanagementmaßnahmen gemäß § 33 Abs. 2 der von ihnen eingesetzten Prüfer gemäß § 4 QuaStEV in der Fassung der Verordnung BGBl. II Nr. 226/2019 zu bedienen haben. § 7 Abs. 4 gilt sinngemäß.

(8) Anträge gemäß § 7 Abs. 2 können frühestens ab Inkrafttreten der gemäß § 7 Abs. 6 zu erlassenden Verordnung gestellt werden.

(9) Die Ausschreibung der Funktionen des Direktors sowie seines Stellvertreters ist bereits vor Inkrafttreten dieses Bundesgesetzes zulässig.

Artikel 2

Änderung des Telekommunikationsgesetzes 2021

Das Telekommunikationsgesetz 2021 (TKG 2021), BGBl. I Nr. 190/2021, zuletzt geändert durch das Bundesgesetz BGBl. I Nr. 54/2025, wird wie folgt geändert:

1. § 44 lautet:

„(1) Betreiber und Anbieter haben nach Maßgabe anderer Rechtsvorschriften Maßnahmen für Cybersicherheit zu ergreifen. Für den Fall, dass diese Rechtsvorschriften nicht ausreichen, das in § 1 Abs. 2 Z 4 genannte Ziel der Aufrechterhaltung der Sicherheit der Netze und Dienste zu gewährleisten, ist die Regulierungsbehörde ermächtigt, im Einvernehmen mit dem Bundeskanzler, dem Bundesminister für Wohnen, Kunst, Kultur, Medien und Sport und der Cybersicherheitsbehörde unter Bedachtnahme auf relevante internationale Vorschriften, die nationale Cybersicherheitsstrategie, die Art des Netzes oder des

Dienstes, die technischen Möglichkeiten und sonstige schutzwürdige Interessen von Nutzern mit Verordnung nähere Bestimmungen über technische und organisatorische Sicherheitsmaßnahmen festzulegen.

(2) In der Verordnung nach Abs. 1 kann auch angeordnet werden, dass Betreiber von öffentlichen Kommunikationsnetzen oder öffentlichen Kommunikationsdiensten, die ihre Netze oder Dienste in Österreich betreiben und über keinen Aufenthalt oder Sitz in der Europäischen Union verfügen, eine inländische Zustelladresse bekannt geben müssen, an die in Verfahren nach diesem Bundesgesetz rechtskräftig zugestellt werden kann. Dies kann auch für Hersteller von Komponenten eines Netzes für elektronische Kommunikation oder für Bereitsteller von Dienstleistungen für solche Netze angeordnet werden, sofern sie ihre Waren oder Dienstleistungen in Österreich anbieten oder nach Österreich importiert werden und sie über keinen Aufenthalt oder Sitz in der Europäischen Union verfügen.

(3) Der RTR-GmbH, Fachbereich Telekommunikation und Post, im Rahmen der ihr übertragenen Aufgaben, werden darüber hinaus folgende Aufgaben übertragen:

1. Durchführung einer Branchenrisikoanalyse in Zusammenarbeit mit dem Bundeskanzleramt, den Bundesministerien für Wohnen, Kunst, Kultur, Medien und Sport, für Inneres und für Landesverteidigung, dem CSIRT sowie den Betreibern von Fest- und von Mobilfunknetzen in Abständen von jeweils zwei Jahren sowie Erstellung eines Abschlussberichts, der den teilnehmenden Institutionen zur Verfügung zu stellen und unter Beachtung des notwendigen Schutzes kritischer Infrastrukturen in einer bereinigten Version auf der RTR-Website zu veröffentlichen ist;
2. Mitwirkung an der Erstellung eines Mustersicherheitskonzepts für Betreiber gemäß § 4 Z 25 und Anbieter gemäß § 4 Z 36;
3. Mitwirkung in Arbeitsgruppen der ENISA sowie der NIS-Kooperationsgruppe.

(4) Eine Verordnung gemäß Abs. 1 ist in Bezug auf Rundfunknetze und die Übertragung von Rundfunksignalen von der KommAustria zu erlassen. Sind bei der Erledigung der in Abs. 3 genannten Aufgaben auch Rundfunknetze oder die Übertragung von Rundfunksignalen betroffen, ist insoweit das Einvernehmen mit der KommAustria herzustellen.“

2. In § 188 Abs. 5 entfallen die Z 1 bis 5 und erhalten die bisherigen Z 6 bis 16 die Ziffernbezeichnung „1.“ bis „11.“.

3. In § 198 entfällt Z 9 und erhalten die bisherigen Z 10 bis 26 die Ziffernbezeichnung „9.“ bis „25.“.

4. In § 200 Abs. 1 wird der Verweis „§ 198 Z 13, 17 und 20“ durch den Verweis „§ 198 Z 12, 16 und 19“ ersetzt.

5. In § 200 Abs. 5 wird der Verweis „§ 198 Z 13“ durch den Verweis „§ 198 Z 12“ ersetzt.

6. Dem § 217 wird folgender Abs. 5 angefügt:

„(5) § 44, § 188 Abs. 5, § 198 sowie § 200 Abs. 1 und 5 in der Fassung des Bundesgesetzes BGBl. I Nr. 94/2025 treten nach Ablauf von neun Monaten nach der Kundmachung dieses Bundesgesetzes mit dem nächstfolgenden Monatsersten in Kraft.“

Artikel 3

Änderung des Gesundheitstelematikgesetzes 2012

Das Gesundheitstelematikgesetz 2012 (GTelG 2012), BGBl. I Nr. 111/2012, zuletzt geändert durch das Bundesgesetz BGBl. I Nr. 71/2025, wird wie folgt geändert:

1. Im Inhaltsverzeichnis lautet der Eintrag zu § 8a:

„§ 8a Cybersicherheit und -resilienz im Gesundheitswesen“.

2. § 8a samt Überschrift lautet:

„Cybersicherheit und -resilienz im Gesundheitswesen

§ 8a. (1) Der für das Gesundheitswesen zuständige Bundesminister oder die zuständige Bundesministerin hat als datenschutzrechtlich Verantwortlicher (Art. 4 Z 7 DSGVO) zur Gewährleistung der Cybersicherheit und -resilienz im Gesundheitswesen ein spezialisiertes Cybersicherheits-Kompetenzteam, das „Austrian HealthCERT“, einzurichten und zu betreiben. Der für das

Gesundheitswesen zuständige Bundesminister oder die zuständige Bundesministerin kann sich für die Wahrnehmung dieser Aufgabe des Austrian HealthCERT eines Dienstleisters bedienen.

(2) Das Austrian HealthCERT hat die Aufgaben eines sektorspezifischen Computer-Notfallteams gemäß § 8 des Netz- und Informationssystemsicherheitsgesetzes (NISG 2026), BGBl. I Nr. 94/2025, für den Sektor Gesundheitswesen gemäß § 2 Z 5 NISG 2026 wahrzunehmen und dabei die Voraussetzungen gemäß § 9 Abs. 1 NISG 2026, mit Ausnahme von Z 8 zu erfüllen. Die Bestimmungen des NISG 2026 über die Ermächtigung der Cybersicherheitsbehörde zur Einrichtung von sektorspezifischen CSIRTs kommen nicht zur Anwendung.

(3) Wesentliche und wichtige Einrichtungen gemäß den §§ 24 ff NISG 2026, die dem Sektor Gesundheitswesen gemäß § 2 Z 5 NISG 2026 angehören, haben zur Erfüllung ihrer auf den Sektor Gesundheitswesen bezogenen Meldepflichten gemäß den §§ 34 und 37 NISG 2026 Meldungen an das Austrian HealthCERT zu erbringen. Andere Meldepflichten bleiben hiervon unberührt.

(4) Der für das Gesundheitswesen zuständige Bundesminister oder die zuständige Bundesministerin kann dem Austrian HealthCERT mit Verordnung weitere Aufgaben zur Gewährleistung der Sicherheit und der Resilienz von Netz- und Informationssystemen im Gesundheitswesen übertragen.

(5) Der für das Gesundheitswesen zuständige Bundesminister oder die zuständige Bundesministerin hat zu seiner oder ihrer Unterstützung in strategischen Angelegenheiten der Cybersicherheit und der Cyberresilienz im Gesundheitswesen einen Cybersicherheitsausschuss für den Bereich Gesundheitswesen („Cybersicherheitsausschuss eHealth [CSAeH]“) einzurichten. Diesem haben die Vertragspartner der Vereinbarung gemäß Art. 15a B-VG über die Organisation und Finanzierung des Gesundheitswesens, unter Vorsitz des Bundes, anzugehören. Der CSAeH hat eine Geschäftsordnung zu beschließen, die die Erfüllung der ihm übertragenen Aufgaben sicherstellt. Die Geschäftsordnung bedarf für ihre Wirksamkeit der Genehmigung des für das Gesundheitswesen zuständigen Bundesministers oder der zuständigen Bundesministerin.“

Dem § 26 wird folgender Abs. 22 angefügt:

„(22) Das Inhaltsverzeichnis sowie § 8a samt Überschrift in der Fassung des Bundesgesetzes BGBl. I Nr. 94/2025 treten nach Ablauf von neun Monaten nach der Kundmachung dieses Bundesgesetzes mit dem nächstfolgenden Monatsersten in Kraft.“

Van der Bellen

Stocker

	Unterzeichner	serialNumber=734173660,CN=Bundeskanzleramt,C=AT
	Datum/Zeit	2025-12-23T14:18:06+01:00
	Prüfinformation	Informationen zur Prüfung des elektronischen Siegels bzw. der elektronischen Signatur finden Sie unter: https://www.signaturpruefung.gv.at Informationen zur Prüfung des Ausdrucks finden Sie unter: https://www.bundeskanzleramt.gv.at/verifizierung
	Hinweis	Dieses Dokument wurde amtssigniert.